

ICT2212

Ethical Hacking

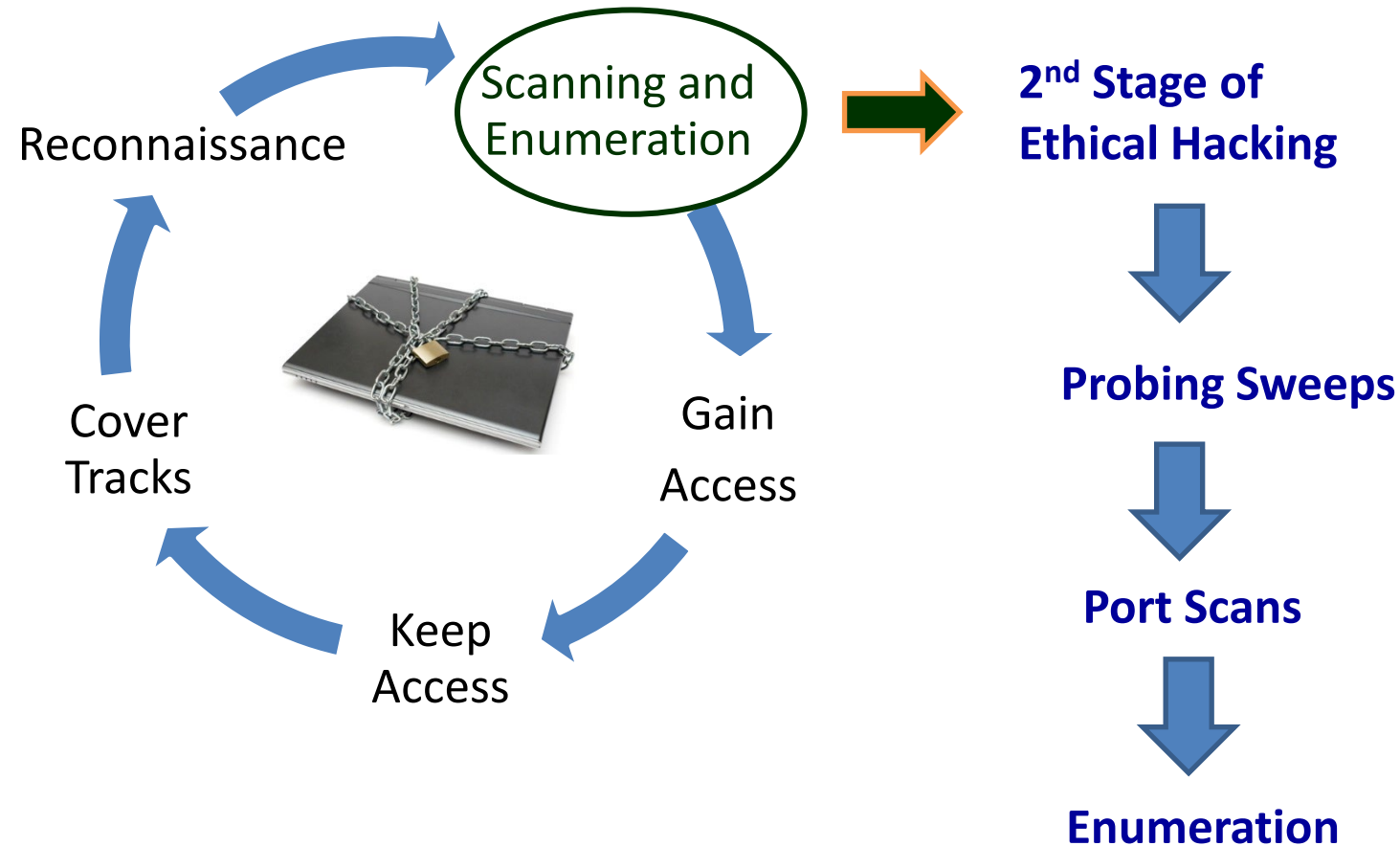


Scanning and Enumeration
A/Prof Guo Huaqun (Linda)

Acknowledgement

- This set of slides is based on a version from Dr. Raymond Chan (Some slides developed by A/Prof Peter Loh) and then updated and added some slides by A/Prof. Guo Huaqun (Linda).

Introduction to Scanning and Enumeration



Determine if system is up and probing for weakness

How is this different from reconnaissance (foot-printing)?

Reconnaissance vs Foot-printing



Reconnaissance: Which house?



Foot-printing: Survey the house;
potential entry points?



Information gathered increases

Foot-printing vs Scanning

- Reconnaissance is like locating a house, foot-printing is like surveying the house exterior, scanning is like finding the doors and windows and if they are open or close
- During foot-printing, attackers can obtain:
 - Domain names and IP addresses
 - Server, OS, network info
 - Essentially, discovering attack surface
- Scanning wants to determine:
 - Is the system alive (or not/air-gapped)?
 - Which system ports are open and listening for inbound network traffic?
 - What other systems are reachable ?



Scanning Techniques

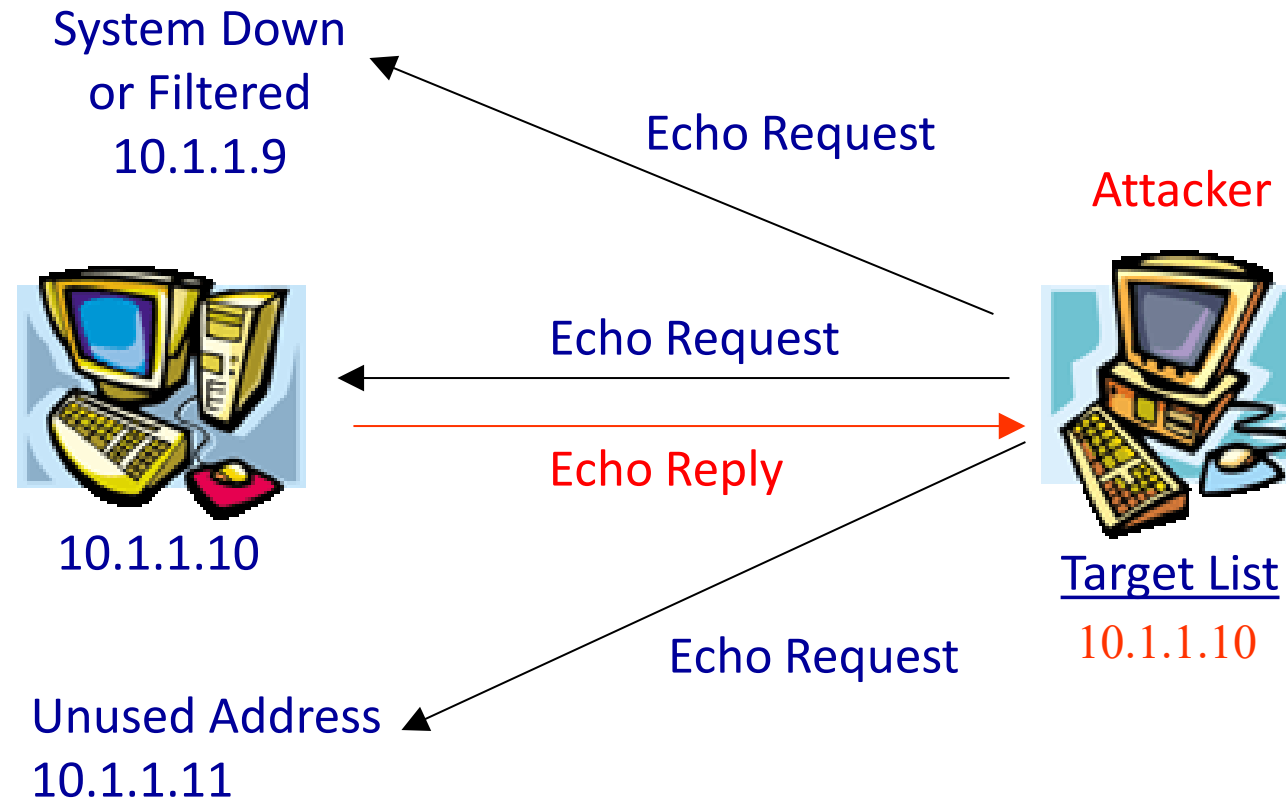
- Determining if the system is alive:
 - ***Probing sweeps*** -
 - Ping sweeps (**ICMP ECHO** and **NON-ECHO** requests)
 - **TCP** and **UDP** Sweeps
- Determining which ports are open / closed / filtered:
 - ***Basic Port Scanning***
 - ***Advanced Port Scanning***
- Detecting reachable systems:
 - ***Route Tracing***
 - ***APT – advance worms***

PROBING SWEEPS

PING Overview

- PING (Packet INternet Groper)
 - A utility designed to determine whether a system at a specific IP address is alive
- Using PING, attackers can send an Internet Control Message Protocol (ICMP) echo request to a range of addresses to determine which systems are “up and running”
 - Every system that is up will respond with an echo reply, providing a list of potential targets

PING Sweeps – ICMP Echo



KALI LINUX – *ping*, *fping* (fping allows you to ping multiple hosts)
WINDOWS – *ping*

KALI LINUX – fping Demo

```
root@kali2204:~# fping -A ntu.edu.sg
155.69.7.173 is unreachable
root@kali2204:~# fping -A sutd.edu.sg
202.94.70.56 is alive
root@kali2204:~# fping -A nus.edu.sg
137.132.21.27 is alive
root@kali2204:~# fping -A singaporetech.edu.sg
103.28.249.9 is alive
root@kali2204:~#
root@kali2204:~# fping nus.edu.sg ntu.edu.sg smu.edu.sg sutd.edu.sg singaporetec
h.edu.sg
nus.edu.sg is alive
sutd.edu.sg is alive
smu.edu.sg is alive
singaporetech.edu.sg is alive
ntu.edu.sg is unreachable
root@kali2204:~#
```

- **fping** uses ICMP protocol to determine if a host is up, can specify any number of hosts on the command line, or specify a file containing the lists of hosts to ping
- Instead of trying one host until it timeouts or replies, **fping** will send out a ping packet and move on to the next host in a round-robin fashion
- If a host replies, it is noted and removed from the list of hosts to check. If a host does not respond within time limit and/or retry limit it'll be considered unreachable

Kali Linux – ping Demo

```
root@kali2204:~# ping -h
Usage: ping [-aAbBdDfhLnOqrRUvV64] [-c count] [-i interval] [-I interface]
        [-m mark] [-M pmtudisc_option] [-l preload] [-p pattern] [-Q tos]
        [-s packetsize] [-S sndbuf] [-t ttl] [-T timestamp_option]
        [-w deadline] [-W timeout] [hop1 ...] destination
Usage: ping -6 [-aAbBdDfhLnOqrRUvV] [-c count] [-i interval] [-I interface]
        [-l preload] [-m mark] [-M pmtudisc_option]
        [-N nodeinfo_option] [-p pattern] [-Q tclass] [-s packetsize]
        [-S sndbuf] [-t ttl] [-T timestamp_option] [-w deadline]
        [-W timeout] destination
root@kali2204:~# ping -c4 155.69.7.173

root@kali2204:~# ping -c4 192.168.248.2
PING 192.168.248.2 (192.168.248.2) 56(84) bytes of data.
64 bytes from 192.168.248.2: icmp_seq=1 ttl=128 time=0.115 ms
64 bytes from 192.168.248.2: icmp_seq=2 ttl=128 time=0.120 ms
64 bytes from 192.168.248.2: icmp_seq=3 ttl=128 time=0.119 ms
64 bytes from 192.168.248.2: icmp_seq=4 ttl=128 time=0.116 ms

--- 192.168.248.2 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3073ms
rtt min/avg/max/mdev = 0.115/0.117/0.120/0.011 ms
root@kali2204:~#
```

PING Sweep – Kali Linux Demo

```
File Edit View Search Terminal Help
root@kali2204:~# for i in {1..254}; do ping -c1 -w1 192.168.248.$i | grep "64 by
tes"; done
64 bytes from 192.168.248.2: icmp_seq=1 ttl=128 time=0.172 ms
64 bytes from 192.168.248.128: icmp_seq=1 ttl=64 time=0.072 ms
root@kali2204:~#

Starting Nmap 7.40 ( https://nmap.org ) at 2017-09-13 02:50 +08
Nmap scan report for 192.168.248.1
Host is up, received arp-response (0.000066s latency).
MAC Address: 00:50:56:C0:00:08 (VMware)
Nmap scan report for 192.168.248.2
Host is up, received arp-response (0.00013s latency).
MAC Address: 00:50:56:F9:B6:F7 (VMware)
Nmap scan report for 192.168.248.254
Host is up, received arp-response (0.000058s latency).
MAC Address: 00:50:56:F4:80:45 (VMware)
Nmap scan report for 192.168.248.128
Host is up, received localhost-response.
Nmap done: 254 IP addresses (4 hosts up) scanned in 1.98 seconds
root@kali2204:~#
```

Tools – easier way to ping sweep but **any false negatives?**

Windows – ping Demo

```
C:\Users\A88252>ipconfig

Windows IP Configuration

Wireless LAN adapter Wireless Network Connection 2:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix . :

Wireless LAN adapter Wireless Network Connection:

    Connection-specific DNS Suffix . : sf.siat.edu.sg
    Link-local IPv6 Address . . . . . : fe80::5868:5890:7427:cd7e%15
    IPv4 Address. . . . . : 172.27.146.144
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 172.27.146.1
```

```
C:\Users\A88252>ping -a 172.27.146.144

Pinging SIT-NB-X240-284.sf.siat.edu.sg [172.27.146.144] with 32 bytes of data:
Reply from 172.27.146.144: bytes=32 time<1ms TTL=128
Reply from 172.27.146.144: bytes=32 time<1ms TTL=128
Reply from 172.27.146.144: bytes=32 time<1ms TTL=128
Reply from 172.27.146.144: bytes=32 time<1ms TTL=128

Ping statistics for 172.27.146.144:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 0ms, Maximum = 0ms, Average = 0ms
```

PING Sweep – Windows Demo

```
C:\Users\A88252>FOR /L %i in (140,1,200) do @ping -n 1 172.27.146.%i | find "bytes=32"
Reply from 172.27.146.142: bytes=32 time=6ms TTL=128
Reply from 172.27.146.144: bytes=32 time<1ms TTL=128
Reply from 172.27.146.151: bytes=32 time=7ms TTL=128
Reply from 172.27.146.157: bytes=32 time=1807ms TTL=64
Reply from 172.27.146.158: bytes=32 time=55ms TTL=128
Reply from 172.27.146.167: bytes=32 time=60ms TTL=64
Reply from 172.27.146.168: bytes=32 time=23ms TTL=64
Reply from 172.27.146.184: bytes=32 time=210ms TTL=128
Reply from 172.27.146.187: bytes=32 time=95ms TTL=64
Reply from 172.27.146.193: bytes=32 time=28ms TTL=255
Reply from 172.27.146.197: bytes=32 time=6ms TTL=128
Reply from 172.27.146.200: bytes=32 time=136ms TTL=64
```

Syntax

```
FOR /L %%parameter IN (start,step,end) DO command
```

Key

<i>start</i>	: The first number
<i>step</i>	: The amount by which to increment the sequence
<i>end</i>	: The last number
 <i>command</i>	 : The command to carry out, including any command-line parameters.
 <i>%%parameter</i>	 : A replaceable parameter: in a batch file use %G (on the command line %G)

So (20,-5,10) would generate the sequence (20 15 10)

PING Sweep – FOR Syntax

Conditionally perform a command several times.

syntax-FOR-Files

```
FOR %%parameter IN (set) DO command
```

syntax-FOR-Files-Rooted at Path

```
FOR /R [[drive:]path] %%parameter IN (set) DO command
```

syntax-FOR-Folders

```
FOR /D %%parameter IN (folder_set) DO command
```

syntax-FOR-List of numbers

```
FOR /L %%parameter IN (start,step,end) DO command
```

syntax-FOR-File contents

```
FOR /F ["options"] %%parameter IN (filename) DO command
```

```
FOR /F ["options"] %%parameter IN ("Text string to process") DO command
```

syntax-FOR-Command Results

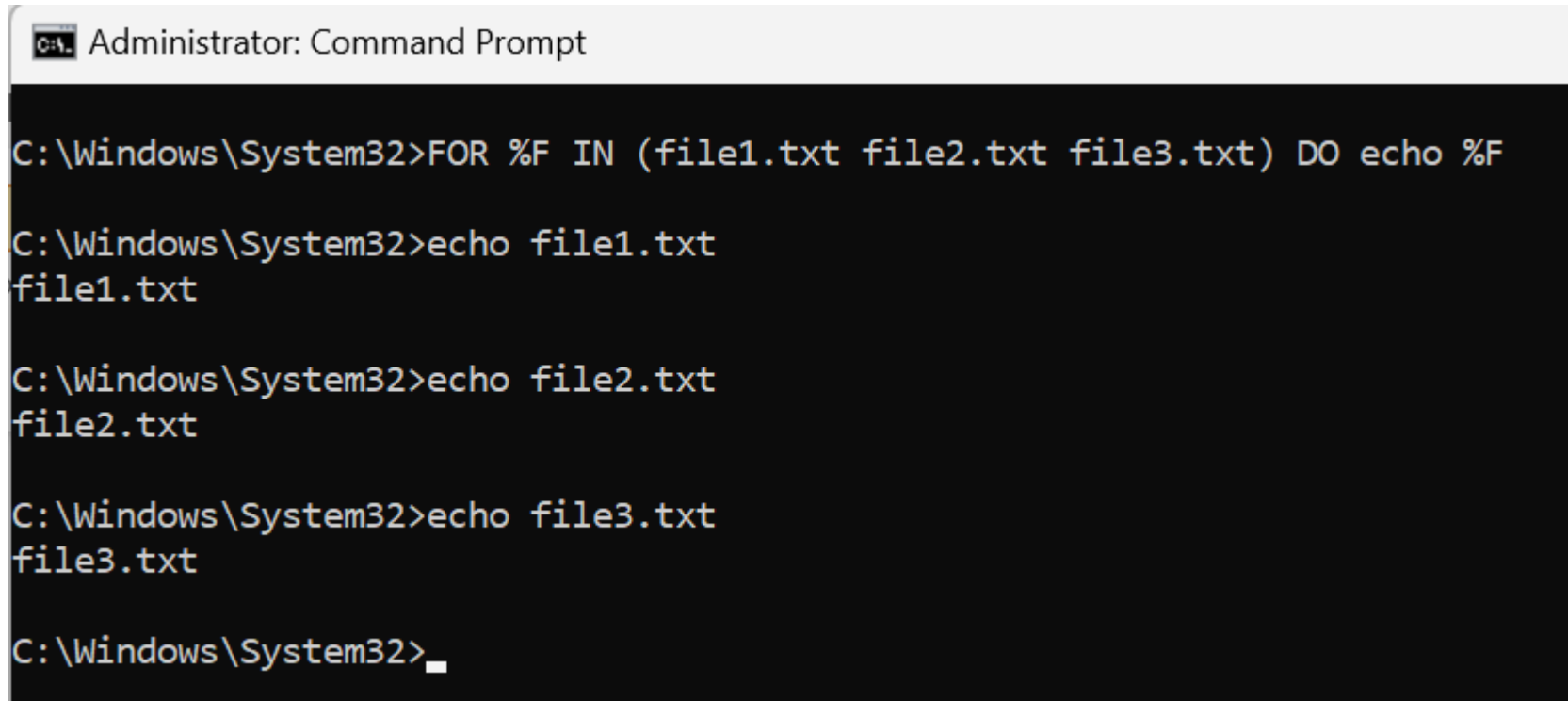
```
FOR /F ["options"] %%parameter IN ('command to process') DO command
```

The operation of the FOR command can be summarised as...

- Take a set of data
- Make a FOR Parameter %%G equal to some part of that data
- Perform a command (optionally using the parameter as part of the command).
- Repeat for each item of data

PING Sweep – FOR Syntax

- FOR %F IN (file1.txt file2.txt file3.txt) DO echo %F
- →Output



```
Administrator: Command Prompt

C:\Windows\System32>FOR %F IN (file1.txt file2.txt file3.txt) DO echo %F

C:\Windows\System32>echo file1.txt
file1.txt

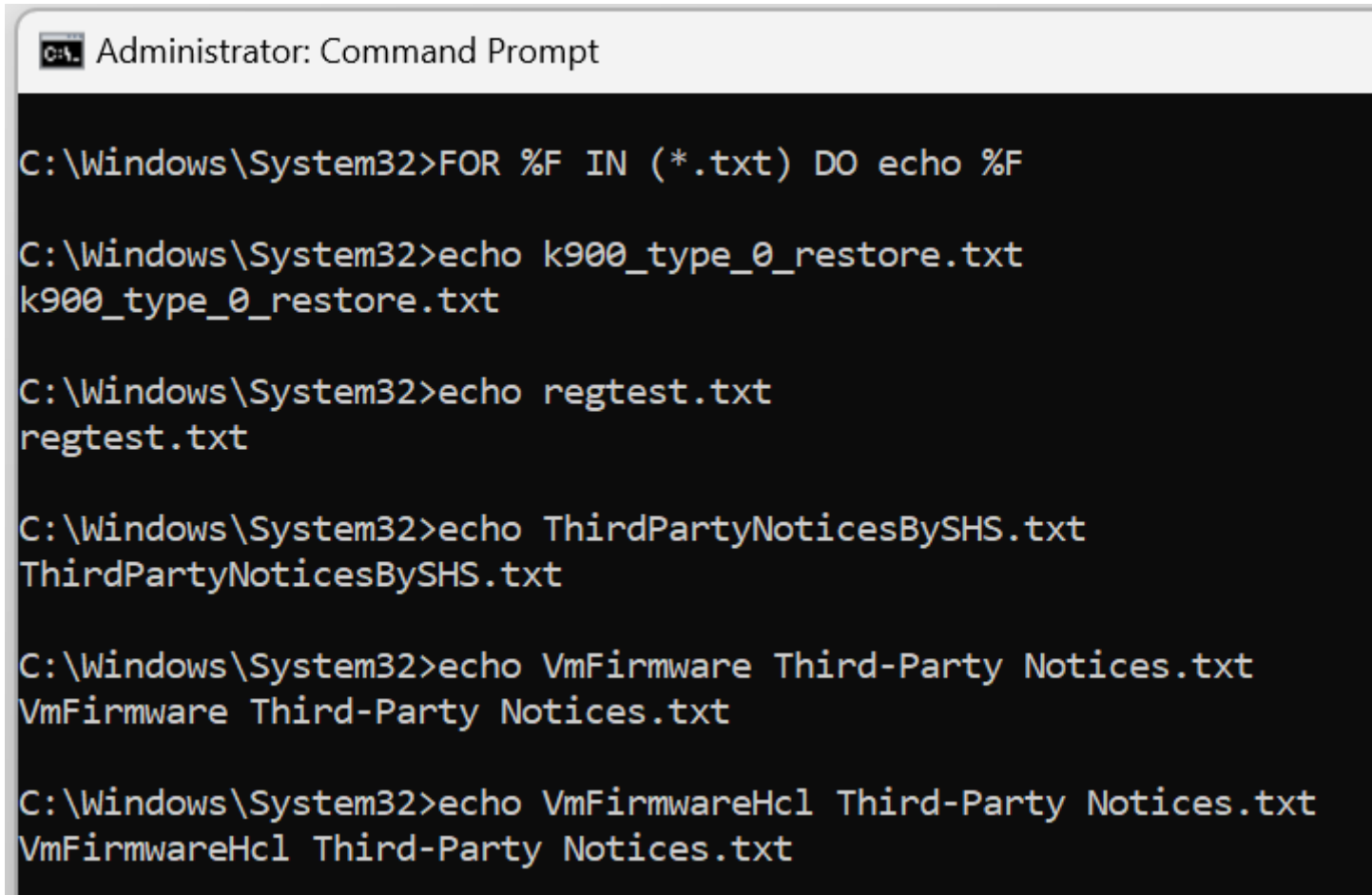
C:\Windows\System32>echo file2.txt
file2.txt

C:\Windows\System32>echo file3.txt
file3.txt

C:\Windows\System32>_
```

PING Sweep – FOR Syntax

- FOR %F IN (*.txt) DO echo %F
- →Output



```
Administrator: Command Prompt

C:\Windows\System32>FOR %F IN (*.txt) DO echo %F

C:\Windows\System32>echo k900_type_0_restore.txt
k900_type_0_restore.txt

C:\Windows\System32>echo regtest.txt
regtest.txt

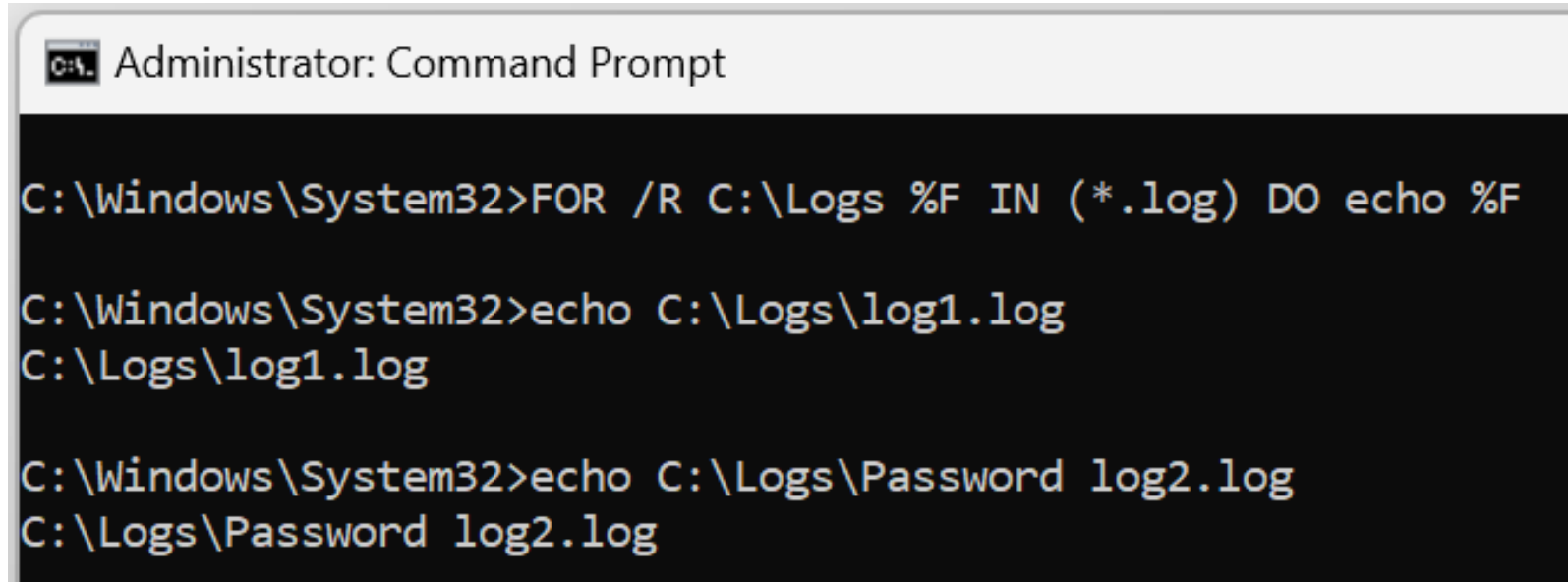
C:\Windows\System32>echo ThirdPartyNoticesBySHS.txt
ThirdPartyNoticesBySHS.txt

C:\Windows\System32>echo VmFirmware Third-Party Notices.txt
VmFirmware Third-Party Notices.txt

C:\Windows\System32>echo VmFirmwareHcl Third-Party Notices.txt
VmFirmwareHcl Third-Party Notices.txt
```

PING Sweep – FOR Syntax

- FOR /R C:\Logs %F IN (*.log) DO echo %F
- →Output



```
Administrator: Command Prompt

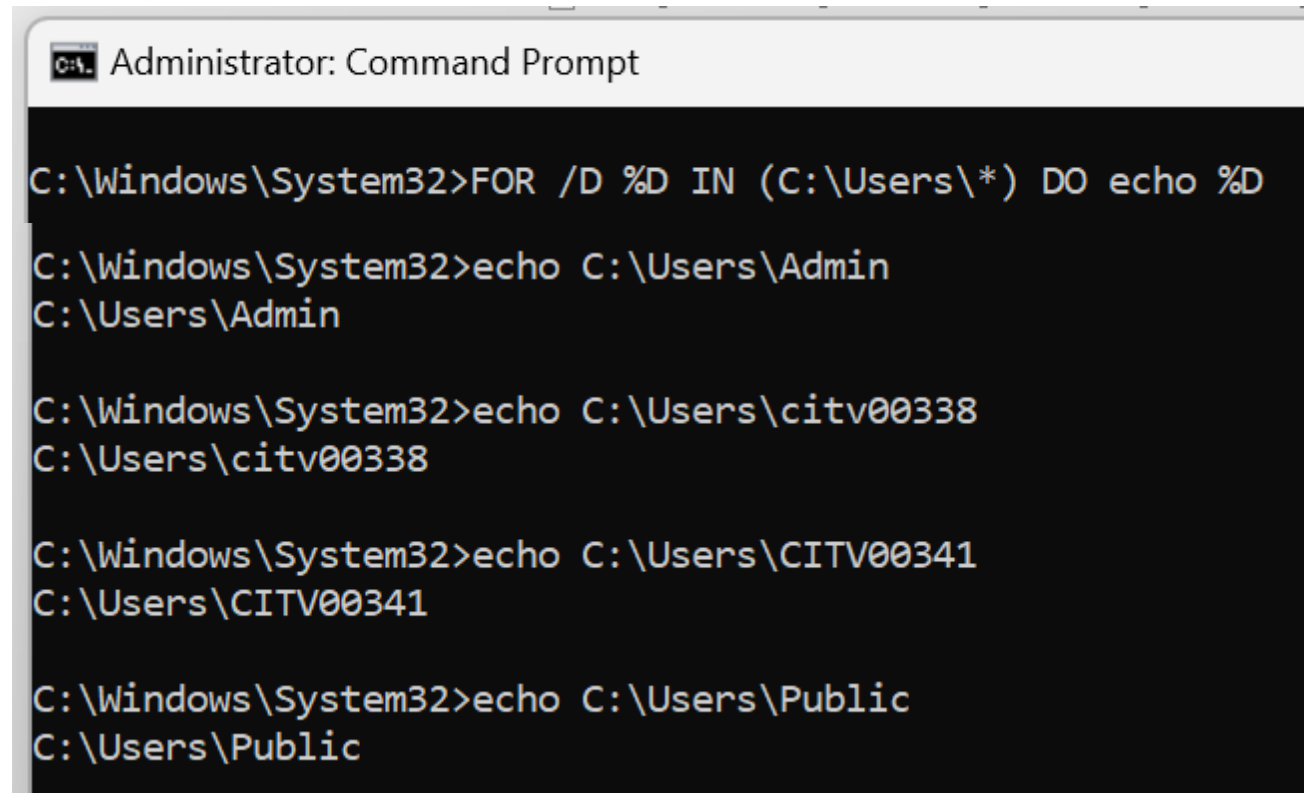
C:\Windows\System32>FOR /R C:\Logs %F IN (*.log) DO echo %F

C:\Windows\System32>echo C:\Logs\log1.log
C:\Logs\log1.log

C:\Windows\System32>echo C:\Logs\Password log2.log
C:\Logs\Password log2.log
```

PING Sweep – FOR Syntax

- FOR /D %D IN (C:\Users*) DO echo %D
- → Output



```
Administrator: Command Prompt

C:\Windows\System32>FOR /D %D IN (C:\Users\*) DO echo %D

C:\Windows\System32>echo C:\Users\Admin
C:\Users\Admin

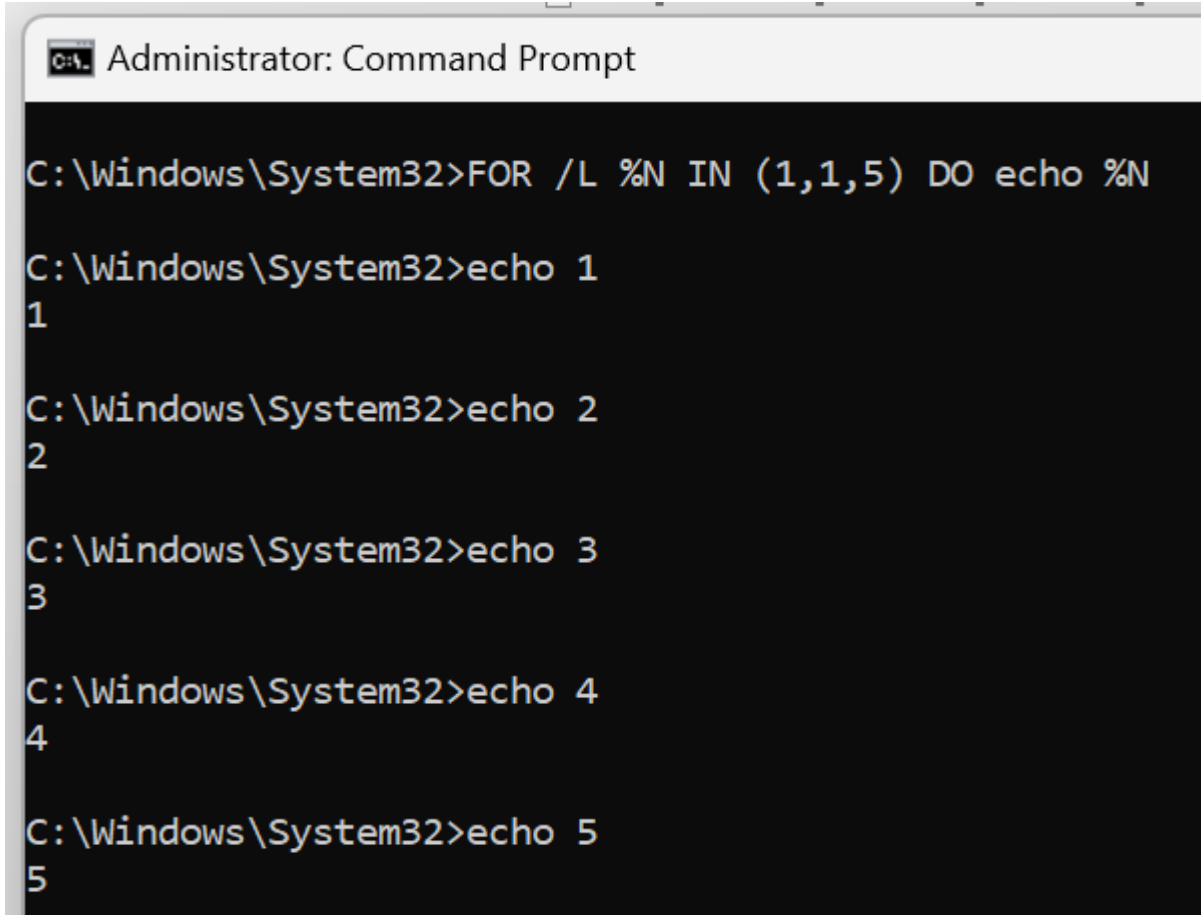
C:\Windows\System32>echo C:\Users\citv00338
C:\Users\citv00338

C:\Windows\System32>echo C:\Users\CITV00341
C:\Users\CITV00341

C:\Windows\System32>echo C:\Users\Public
C:\Users\Public
```

PING Sweep – FOR Syntax

- FOR /L %N IN (1,1,5) DO echo %N
- → Output



```
Administrator: Command Prompt

C:\Windows\System32>FOR /L %N IN (1,1,5) DO echo %N

C:\Windows\System32>echo 1
1

C:\Windows\System32>echo 2
2

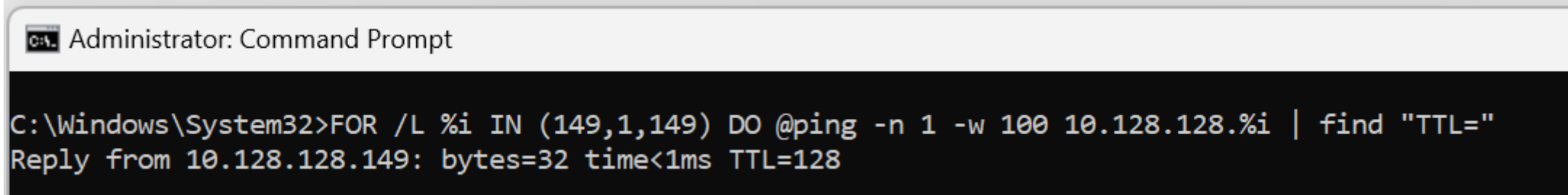
C:\Windows\System32>echo 3
3

C:\Windows\System32>echo 4
4

C:\Windows\System32>echo 5
5
```

Important distinction: %%F vs %F

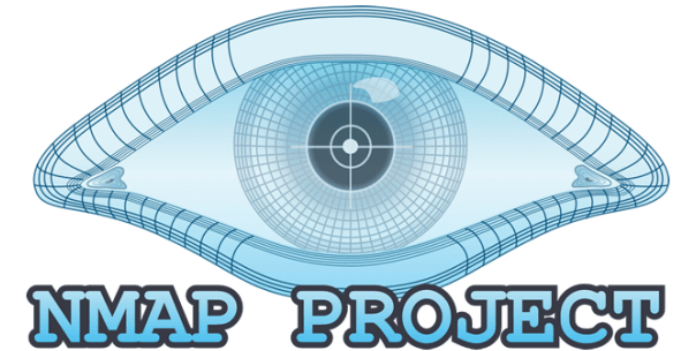
- In a batch file, normally use: %%F
- At the interactive Command Prompt, normally use: %F
 - In the above examples, Windows CMD is used.
 - 10.128.128.149
 - FOR /L %i IN (149,1,149) DO @ping -n 1 -w 100 10.128.128.%i | find "TTL="



```
C:\Windows\System32>FOR /L %i IN (149,1,149) DO @ping -n 1 -w 100 10.128.128.%i | find "TTL="
Reply from 10.128.128.149: bytes=32 time<1ms TTL=128
```

Nmap

- Nmap (Network Mapper) is a free and open-source network scanner created by Gordon Lyon
- Included lots of useful tools, like nc, netcat
- A GUI called Zenmap:
 - Zenmap: <https://nmap.org/zenmap/>



Nmap Demo 1 – Ping Sweep

Command: `nmap -sn 172.27.146.200-255`

Hosts Services

OS Host

- 172.27.146.200
- 172.27.146.201
- 172.27.146.213
- 172.27.146.215
- 172.27.146.216
- 172.27.146.217
- 172.27.146.218
- 172.27.146.223
- 172.27.146.230
- 172.27.146.231
- 172.27.146.238
- 172.27.146.239
- 172.27.146.241
- 172.27.146.249
- 172.27.146.252
- 172.27.146.253

Nmap Output Ports / Hosts Topology Host Details Scans

`nmap -sn 172.27.146.200-255`

```

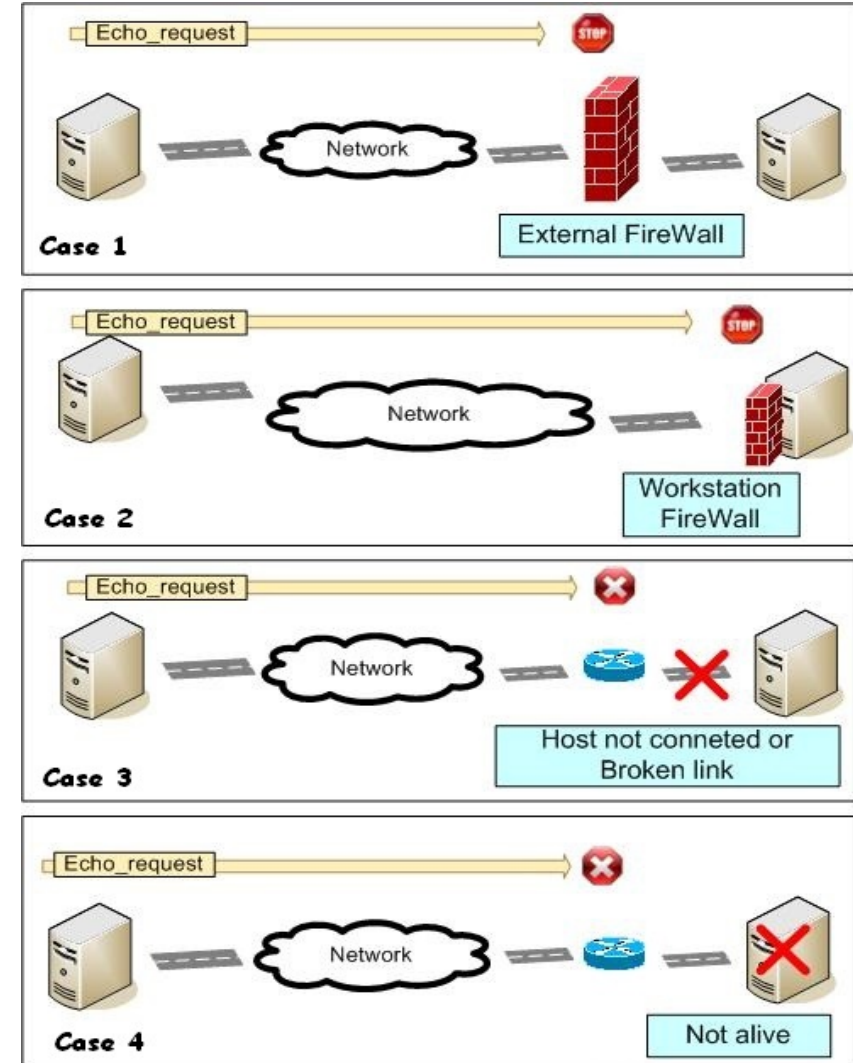
Nmap scan report for 172.27.146.218
Host is up (0.00s latency).
MAC Address: 40:F3:08:C1:0F:75 (Murata Manufacturing Co.)
Nmap scan report for 172.27.146.223
Host is up (0.00s latency).
MAC Address: 54:A0:50:91:32:C8 (Asustek Computer)
Nmap scan report for 172.27.146.230
Host is up (0.010s latency).
MAC Address: F8:E0:79:80:3A:70 (Motorola Mobility)
Nmap scan report for 172.27.146.231
Host is up (0.010s latency).
MAC Address: 6C:88:14:3B:4E:B4 (Intel Corporate)
Nmap scan report for 172.27.146.238
Host is up (0.00s latency).
MAC Address: 54:E4:3A:02:5B:79 (Apple)
Nmap scan report for 172.27.146.239
Host is up (0.00s latency).
MAC Address: 5C:C5:D4:8E:1C:46 (Intel Corporate)
Nmap scan report for 172.27.146.241
Host is up (0.00s latency).
MAC Address: 64:70:02:21:D6:B0 (Tp-link Technologies CO.)
Nmap scan report for 172.27.146.249
Host is up (0.00s latency).
MAC Address: 84:3A:4B:0B:6E:3C (Intel Corporate)
Nmap scan report for 172.27.146.252
Host is up (0.00s latency).
MAC Address: 7C:7A:91:45:75:9F (Intel Corporate)
Nmap scan report for 172.27.146.253
Host is up (0.00s latency).
MAC Address: 7C:7A:91:40:21:8F (Intel Corporate)
Nmap done: 56 IP addresses (16 hosts up) scanned in 10.85 seconds
  
```

-sn: Ping Sweep is only used to find out whether the target is alive, without scanning ports

<https://hackertarget.com/nmap-cheatsheet-a-quick-reference-guide/>

PING Sweeps – Map Target Network

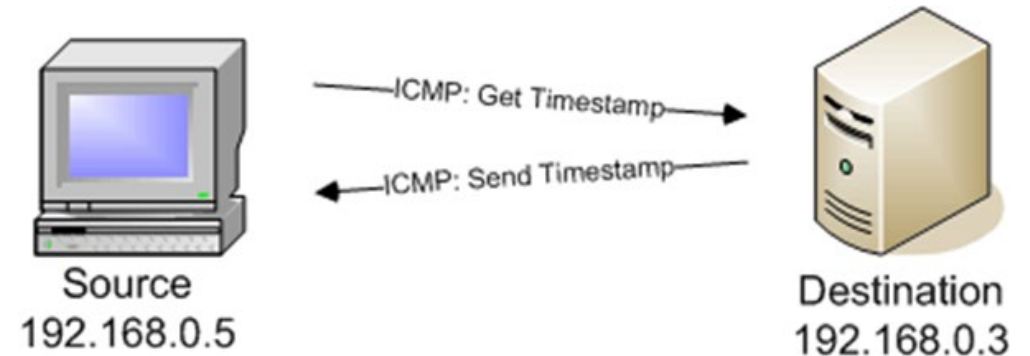
- “Live” systems will send **ICMP Echo Reply - Type 0** message to attacker source IP after receiving an **ICMP Echo Request – Type 8** have been sent but slow (RFC 1122)
 - <http://www.rfc-editor.org/rfc/rfc1122.txt>
- Less effective today than in the past:
 - Scanning and DoS attacks which use ICMP Echo resulted in admin setting systems to drop inbound ICMP echo requests
- May be effective for insiders or attackers who have been able to penetrate at least one system
- Angry IP Scanner: <http://angryip.org/download/>



Ping Sweeps with Non-ECHO ICMP

Ping sweeps can also be performed by:

- ICMP type 13 messages (**TIMESTAMP REQUEST**) and type 14 (**REPLY**)
- The ICMP Time Stamp Request-Reply allows a host to query another for the current time
- Receiving host fills in receive and transmit time stamps (ms)
- RFC 792 - <http://www.rfc-editor.org/rfc/rfc792.txt>
- Receiving an ICMP Timestamp Reply – Type 14 would reveal a host (or a networking device) that is alive and has implemented the ICMP Timestamp messages
- Useful when the more commonly used ICMP Echo packets are specifically blocked or as an alternative



Nmap Demo 2 – Non-Echo Sweep

Hosts Services Nmap Output Ports / Hosts Topology Host Details Scans

JS Host

- 172.30.147.1
- 172.30.147.2
- 172.30.147.8
- 172.30.147.18
- 172.30.147.58
- 172.30.147.70
- 172.30.147.117
- 172.30.147.146
- 172.30.147.161
- 172.30.147.208
- 172.30.147.227
- 172.30.147.232
- 172.30.147.234
- 172.30.147.242
- 172.30.147.252

nmap -PP 172.30.147.200-255

```

1001/tcp open  msmq
2103/tcp open  zephyr-clt
2105/tcp open  eklogin
2107/tcp open  msmq-mgmt
2701/tcp open  sms-rinfo
MAC Address: 5C:C5:D4:AF:24:4F (Intel Corporate)

Nmap scan report for 172.30.147.234
Host is up (0.0028s latency).
All 1000 scanned ports on 172.30.147.234 are filtered (828) or closed (172)
MAC Address: 24:18:1D:1C:B2:B6 (Unknown)

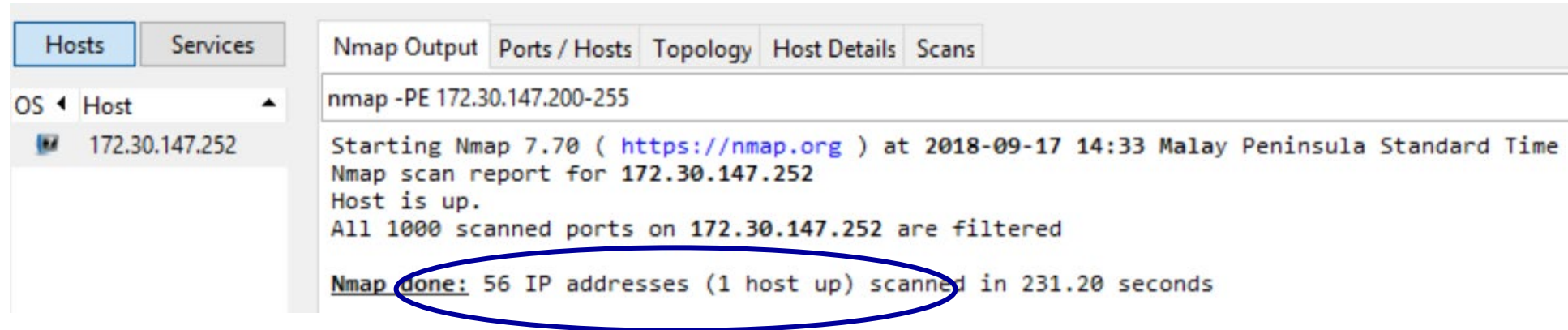
Nmap scan report for 172.30.147.242
Host is up (0.00015s latency).
Not shown: 989 filtered ports
PORT      STATE SERVICE
80/tcp    open  http
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
515/tcp   open  printer
1801/tcp  open  msmq
1947/tcp  open  sentinelarm
2103/tcp  open  zephyr-clt
2105/tcp  open  eklogin
2107/tcp  open  msmq-mgmt
2701/tcp  open  sms-rinfo
MAC Address: 00:E1:8C:B6:03:C8 (Intel Corporate)

Nmap scan report for 172.30.147.252
Host is up.
All 1000 scanned ports on 172.30.147.252 are filtered

Nmap done: 56 IP addresses (6 hosts up) scanned in 277.88 seconds
  
```

-PP: Sweep using ICMP
Non-Echo (timestamp)
includes port scan

Nmap Demo 2 – ICMP Echo Sweep



-PE: ICMP Echo Request with port scan

Ping Sweeps with Non-ECHO ICMP

```
root@kali2204:~# nmap -PP --reason 192.168.248.1-254

Starting Nmap 7.40 ( https://nmap.org ) at 2017-09-13 03:03 +08
Nmap scan report for 192.168.248.1
Host is up, received arp-response (0.000074s latency).
All 1000 scanned ports on 192.168.248.1 are filtered because of 1000 no-response
s
MAC Address: 00:50:56:C0:00:08 (VMware)

Nmap scan report for 192.168.248.2
Host is up, received arp-response (0.000083s latency).
Not shown: 999 closed ports
Reason: 999 resets
PORT      STATE SERVICE REASON
53/tcp    open  domain syn-ack ttl 128
MAC Address: 00:50:56:F9:B6:F7 (VMware)

Nmap scan report for 192.168.248.254
Host is up, received arp-response (0.000084s latency).
All 1000 scanned ports on 192.168.248.254 are filtered because of 1000 no-respon
ses
MAC Address: 00:50:56:F4:80:45 (VMware)

Nmap scan report for 192.168.248.128
Host is up, received localhost-response (0.0000020s latency).
All 1000 scanned ports on 192.168.248.128 are closed because of 1000 resets

Nmap done: 254 IP addresses (4 hosts up) scanned in 8.68 seconds
```

Ping Sweeps with Non-ECHO ICMP

```
Nmap 7.95 ( https://nmap.org )
Usage: nmap [Scan Type(s)] [Options] {target specification}
TARGET SPECIFICATION:
  Can pass hostnames, IP addresses, networks, etc.
  Ex: scanme.nmap.org, microsoft.com/24, 192.168.0.1; 10.0.0-255.1-254
  -iL <inputfilename>: Input from list of hosts/networks
  -iR <num hosts>: Choose random targets
  --exclude <host1[,host2][,host3], ...>: Exclude hosts/networks
  --excludefile <exclude_file>: Exclude list from file
HOST DISCOVERY:
  -sL: List Scan - simply list targets to scan
  -sn: Ping Scan - disable port scan
  -Pn: Treat all hosts as online -- skip host discovery
  -PS/PA/PU/PY[portlist]: TCP SYN, TCP ACK, UDP or SCTP discovery to given p
orts
  -PE/PP/PM: ICMP echo, timestamp, and netmask request discovery probes
  -PO[protocol list]: IP Protocol Ping
  -n/-R: Never do DNS resolution/Always resolve [default: sometimes]
  --dns-servers <serv1[,serv2], ...>: Specify custom DNS servers
  --system-dns: Use OS's DNS resolver
  --traceroute: Trace hop path to each host
SCAN TECHNIQUES:
  -sS/sT/sA/sW/sM: TCP SYN/Connect()/ACK/Window/Maimon scans
  -sU: UDP Scan
  -sN/sF/sX: TCP Null, FIN, and Xmas scans
  --scanflags <flags>: Customize TCP scan flags
```

Summary of ICMP Message Types

ICMP: Message Types

Type	Message
0	Echo reply
3	Destination unreachable
4	Source quench
5	Redirect
8	Echo request
11	Time exceeded
12	Parameter unintelligible
13	Time-stamp request
14	Time-stamp reply
15	Information request
16	Information reply
17	Address mask request
18	Address mask reply

Try with an “Intense scan” Profile
What does an Intense scan do?

**Experiment with the different options
and option combinations in the lab**

<http://nmap.org/book/zenmap-command-line.html>

Intense scan

- A deep, detailed, and somewhat aggressive scan intended to gather as much information as possible about a target, including open ports, running services, OS details, and potential vulnerabilities.
- `nmap -T4 -A -v <target>`
 - T4 → Aggressive timing: speeds up the scan but increases network load and chance of detection.
 - A → Enables OS detection (-O), version detection (-sV), script scanning (-sC), and traceroute (--traceroute).
 - v → Verbose mode: shows more detailed output during scanning.

KALI LINUX – dnsmap Demo

```
root@kali:~# dnsmap singaporetech.edu.sg
dnsmap 0.30 - DNS Network Mapper by pagvac (gnucitizen.org)
[+] searching (sub)domains for singaporetech.edu.sg using built-in wordlist
[+] using maximum random delay of 10 millisecond(s) between requests

blog.singaporetech.edu.sg
IP address #1: 119.31.233.174

fs.singaporetech.edu.sg
IP address #1: 172.21.2.107
[+] warning: internal IP address disclosed

ftp.singaporetech.edu.sg
IP address #1: 103.22.170.98

helpdesk.singaporetech.edu.sg
IP address #1: 172.20.50.29
[+] warning: internal IP address disclosed

library.singaporetech.edu.sg
IP address #1: 52.219.32.94
```

- A network mapper sometimes referred to as a sub-domain brute force tool
- Scan a domain to provide a list of sub-domains that may have vulnerabilities
- Independent of discovery protocol

- DNS Network Mapper – scan domain and provide list of subdomains
- A sub-domain is the part of URL before Top- and Second-Level Domain (e.g. singaporetech is sub-domain in singaporetech.edu.sg)
- Brute force tool used by pentesters during scanning and enumeration phase for infrastructure security assessments
- Discovering internal (private) addresses within an organization can help an attacker in carrying out network-layer attacks to penetrate internal infrastructure.

TCP SWEEPS

What Happens If Target Blocks ICMP?

- Sometimes, a more security-conscious site will block **ICMP** at the border router or firewall
- Both **TCP** (Transmission Control Protocol) and **UDP** (User Datagram Protocol) provides alternative approaches to perform ping sweeps to find if a host is alive on the network
- TCP is connection-oriented (transport layer) protocol that guarantees packet delivery in sequence but may be less efficient (slower) than ICMP, a control-oriented (network layer) protocol
- UDP, however, may be less reliable than TCP but may be used to confirm closed ports

Nmap Demo 3 – TCP Sweep 1/2

```
OS Host
172.30.147.208
172.30.147.227
172.30.147.232
172.30.147.234
172.30.147.242
172.30.147.250
172.30.147.252

nmap -sT 172.30.147.200-255

PORT      STATE SERVICE
80/tcp    open  http
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
515/tcp   open  printer
1801/tcp  open  msmq
1947/tcp  open  sentinelarm
2103/tcp  open  zephyr-clt
2105/tcp  open  eklogin
2107/tcp  open  msmq-mgmt
2701/tcp  open  sms-rcinfo
MAC Address: 00:E1:8C:B6:03:C8 (Intel Corporate)

Nmap scan report for 172.30.147.250
Host is up (0.0090s latency).
All 1000 scanned ports on 172.30.147.250 are filtered
MAC Address: 78:9F:70:37:55:EE (Apple)

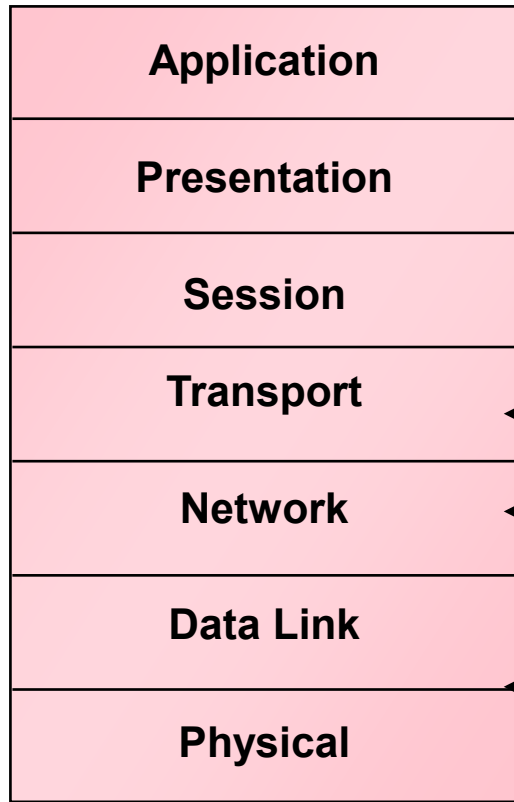
Nmap scan report for 172.30.147.252
Host is up (1.0s latency).
Not shown: 991 closed ports
PORT      STATE SERVICE
135/tcp   open  msrpc
443/tcp   open  https
902/tcp   open  iss-realsecure
912/tcp   open  apex-mesh
2701/tcp  open  sms-rcinfo
8192/tcp  open  sophos
8193/tcp  open  sophos
8194/tcp  open  sophos
16992/tcp open  amt-soap-http

Nmap done: 56 IP addresses (7 hosts up) scanned in 1085.87 seconds
```

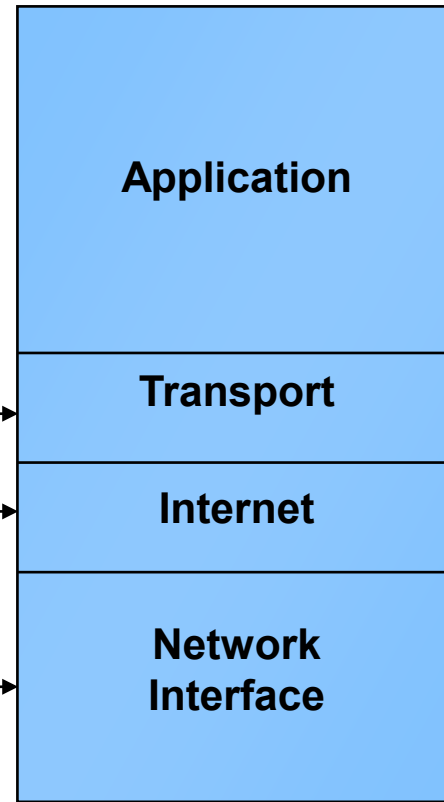
-sT: TCP connect scan

TCP/IP Protocol Stack Review

OSI Reference Model



IP Conceptual Layers



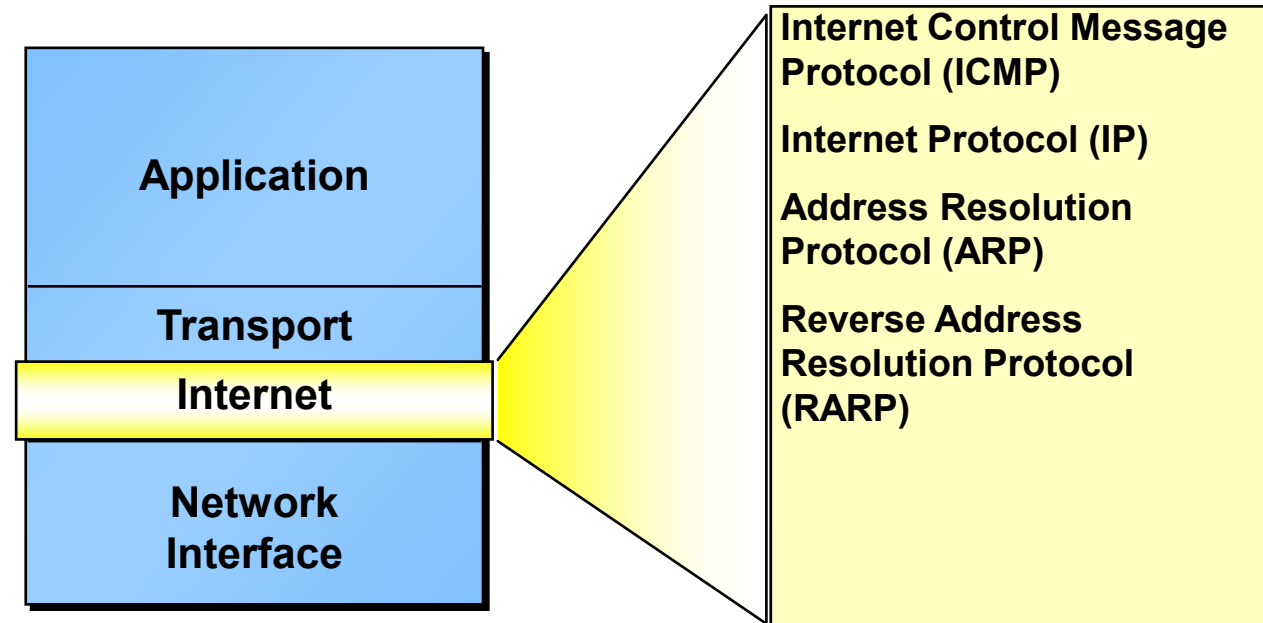
DARPA: Defense
Advanced
Research Projects
Agency

Ethernet, 802.3,
802.5, ATM, FDDI,
and so on

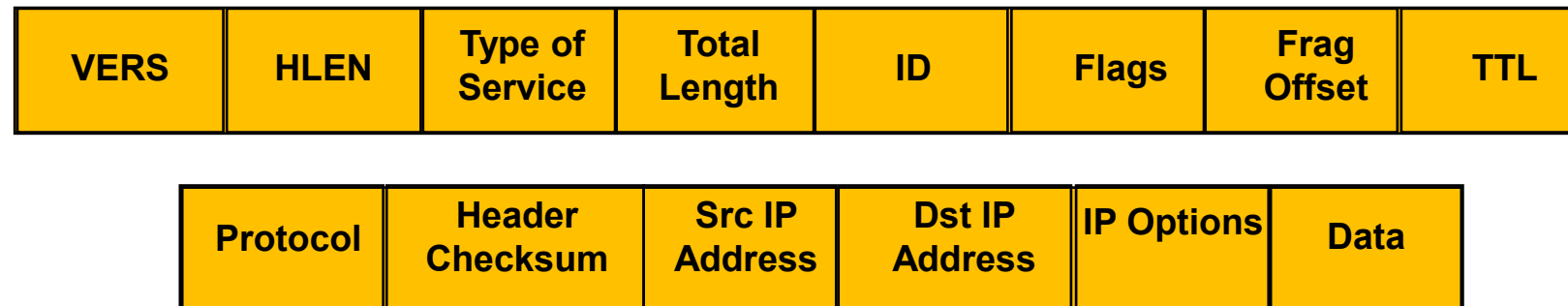
TCP/IP protocols map to the four-layer DARPA conceptual model

ICMP uses Internet Layer

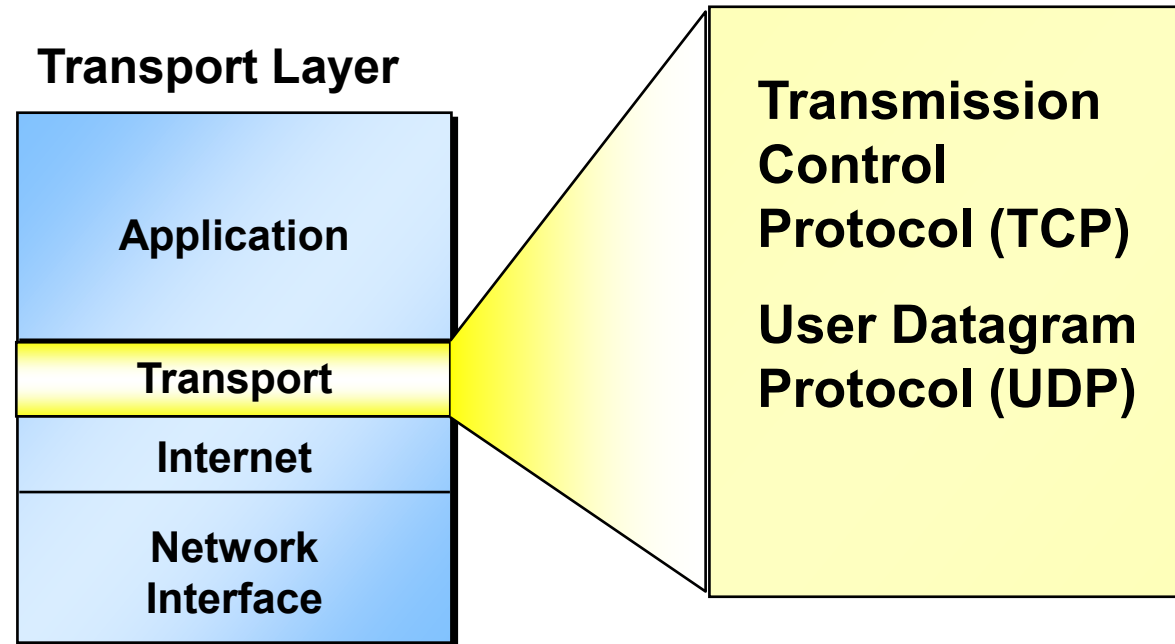
IP Layer



IP Datagram



TCP and UDP uses Transport Layer



TCP Segment Format

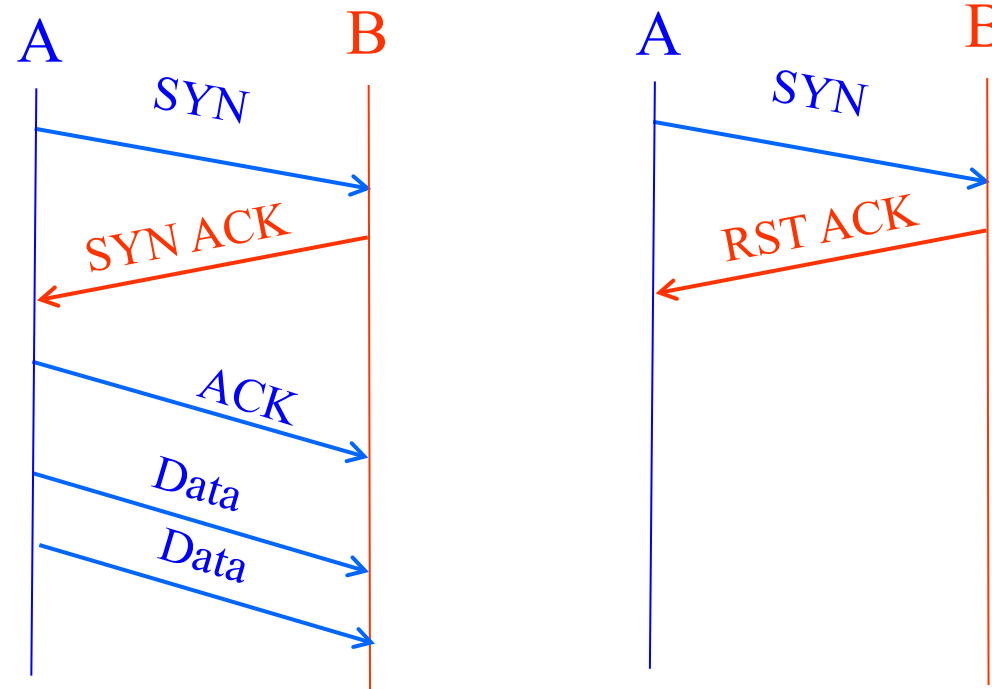
Src Port	Dst Port	Seq #	Ack #	HLEN	Reserved	Code Bits	Window	Check Sum	Urgent Ptr	Option	Data
----------	----------	-------	-------	------	----------	-----------	--------	-----------	------------	--------	------

UDP Segment Format

Src Port	Dst Port	Length	Check Sum	Data
----------	----------	--------	-----------	------

Establishing a TCP Connection

Each host tells its ISN to the other host.



- Three-way handshake to establish connection
 - Host A sends a **SYN** (open) to the host B
 - Host B returns a SYN acknowledgment (**SYN ACK**) – port open
 - Host A sends an **ACK** to acknowledge the SYN ACK
 - If Host B returns an RST acknowledgement (**RST ACK**) – port closed

TCP Sweeps – Packets and Ports Used

- A scanner sends a **SYN** packet to the target:
 - If the target is alive, then the scanner will receive:
 - **SYN ACK** (the port is open)
 - **RST ACK** (the port is closed)
- With the **TCP Sweep** technique, instead of sending **ICMP request** packets we send **TCP SYN** packets to the target network:
 - Receiving a response is a good indication that some system is up there
 - Usually, if one open port is discovered, there is a chance of also discovering filtered ports

TCP Sweep – KALI LINUX Demo

```
root@kali2204:~# nmap -sT 137.132.21.1-10
```

```
Starting Nmap 7.40 ( https://nmap.org ) at 2017-09-13 13:50 +08  
Nmap scan report for 137.132.21.1  
Host is up (0.063s latency).  
Not shown: 999 filtered ports  
PORT      STATE SERVICE  
443/tcp    open  https
```

```
Nmap scan report for exchange.nus.edu.sg (137.132.21.7)  
Host is up (0.059s latency).  
Not shown: 994 filtered ports  
PORT      STATE SERVICE  
80/tcp    open  http  
110/tcp   open  pop3  
143/tcp   open  imap  
443/tcp   open  https  
993/tcp   open  imaps  
995/tcp   open  pop3s
```

```
Nmap scan report for myiteservices.nus.edu.sg (137.132.21.8)  
Host is up (0.055s latency).  
Not shown: 998 filtered ports  
PORT      STATE SERVICE  
80/tcp    open  http  
443/tcp   open  https
```

- **nmap** is a port scanner that can carry out TCP sweeps
- **-sT** is the TCP connect scan, a basic type of port scan, which attempts to connect to every port in turn, and notes whether or not the connection succeeded

TCP Sweep – Windows Demo

```
C:\Windows\system32>for /L %i in (200,1,254) do @nmap -sS 172.27.146.%i

Starting Nmap 6.47 ( http://nmap.org ) at 2015-09-02 12:53 Malay Peninsula Standard Time
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 5.29 seconds

Starting Nmap 6.47 ( http://nmap.org ) at 2015-09-02 12:53 Malay Peninsula Standard Time
Nmap scan report for 172.27.146.201
Host is up (0.0056s latency).
Not shown: 999 filtered ports
PORT      STATE SERVICE
135/tcp   open  msrpc
MAC Address: E8:B1:FC:DF:EB:61 (Intel Corporate)

Nmap done: 1 IP address (1 host up) scanned in 12.47 seconds

Starting Nmap 6.47 ( http://nmap.org ) at 2015-09-02 12:54 Malay Peninsula Standard Time
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 5.21 seconds

Starting Nmap 6.47 ( http://nmap.org ) at 2015-09-02 12:54 Malay Peninsula Standard Time
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 5.26 seconds

Starting Nmap 6.47 ( http://nmap.org ) at 2015-09-02 12:54 Malay Peninsula Standard Time
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 5.23 seconds
```

Can also use Zenmap (Nmap) or Angry IP Scanner

Response of TCP Sweeps

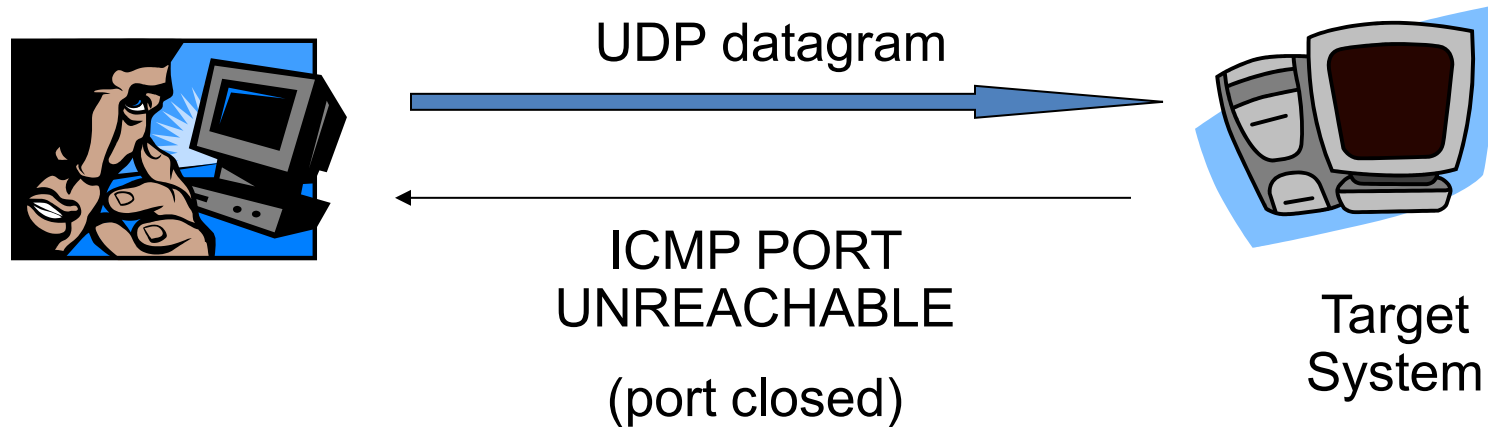
- The response depends on
 - target's OS adhering to RFC 793 (some OSs don't follow the TCP/IP protocol in their implementation e.g. IBM OS/400)
 - nature of the packet sent
 - any firewalls, routers or packet-filtering devices used
- Bear in mind that firewalls (e.g., Iptables) can spoof an RST packet for an IP address or drop it, so TCP Sweeps may not be 100% reliable
- Use a combination of scans (so far, we used scans that depend on target's positive response)

Can we gather any intelligence if a target responds negatively?

UDP SWEEPS

UDP Sweeps

Depends on ICMP PORT UNREACHABLE message (RFC 768)



Unreliable because:

- Routers can drop UDP packets as they cross Internet
- UDP services may not respond when correctly probed
- Firewalls can be configured to drop UDP packets
- Relies on fact that closed UDP port and UDP services will respond

UDP Sweep vs TCP Sweep Demo – 1/3

Target: 172.27.146.210-254 Profile:

Command: nmap -sU 172.27.146.210-254

Hosts Services Nmap Output Ports / Hosts Topology Host Details Scans

OS Host

- 172.27.146.215
- 172.27.146.216
- 172.27.146.223
- 172.27.146.224
- 172.27.146.230
- 172.27.146.238
- 172.27.146.239
- 172.27.146.241
- 172.27.146.249
- 172.27.146.253

nmap -sU 172.27.146.210-254

```

20445/udp open|filtered unknown
21344/udp open|filtered unknown
MAC Address: 54:E4:3A:02:5B:79 (Apple)

Nmap scan report for 172.27.146.239
Host is up (0.00s latency).
All 1000 scanned ports on 172.27.146.239 are open|filtered
MAC Address: 5C:C5:D4:8E:1C:46 (Intel Corporate)

Nmap scan report for 172.27.146.241
Host is up (0.00s latency).
Not shown: 999 open|filtered ports
PORT      STATE SERVICE
137/udp open  netbios-ns
MAC Address: 64:70:02:21:D6:B0 (Tp-link Technologies CO.)

Nmap scan report for 172.27.146.249
Host is up (0.020s latency).
Not shown: 999 open|filtered ports
PORT      STATE SERVICE
137/udp open  netbios-ns
MAC Address: 84:3A:4B:0B:6E:3C (Intel Corporate)

Nmap scan report for 172.27.146.253
Host is up (0.013s latency).
Not shown: 999 open|filtered ports
PORT      STATE SERVICE
137/udp open  netbios-ns
MAC Address: 7C:7A:91:40:21:8F (Intel Corporate)

Nmap done: 45 IP addresses (10 hosts up) scanned in 5495.40 seconds
  
```

Target: 172.27.146.210-254 Profile:

Command: nmap -sS 172.27.146.210-254

Hosts Services Nmap Output Ports / Hosts Topology Host Details Scans

OS Host

- 172.27.146.211
- 172.27.146.213
- 172.27.146.215
- 172.27.146.216
- 172.27.146.217
- 172.27.146.223
- 172.27.146.224
- 172.27.146.230
- 172.27.146.231
- 172.27.146.238
- 172.27.146.239
- 172.27.146.240
- 172.27.146.241
- 172.27.146.242
- 172.27.146.243
- 172.27.146.244
- 172.27.146.249
- 172.27.146.252
- 172.27.146.253
- 172.27.146.254

nmap -sS 172.27.146.210-254

```

Host is up (0.0010s latency).
Not shown: 999 filtered ports
PORT      STATE SERVICE
135/tcp open  msrpc
MAC Address: 5C:C5:D4:AF:2B:D9 (Intel Corporate)

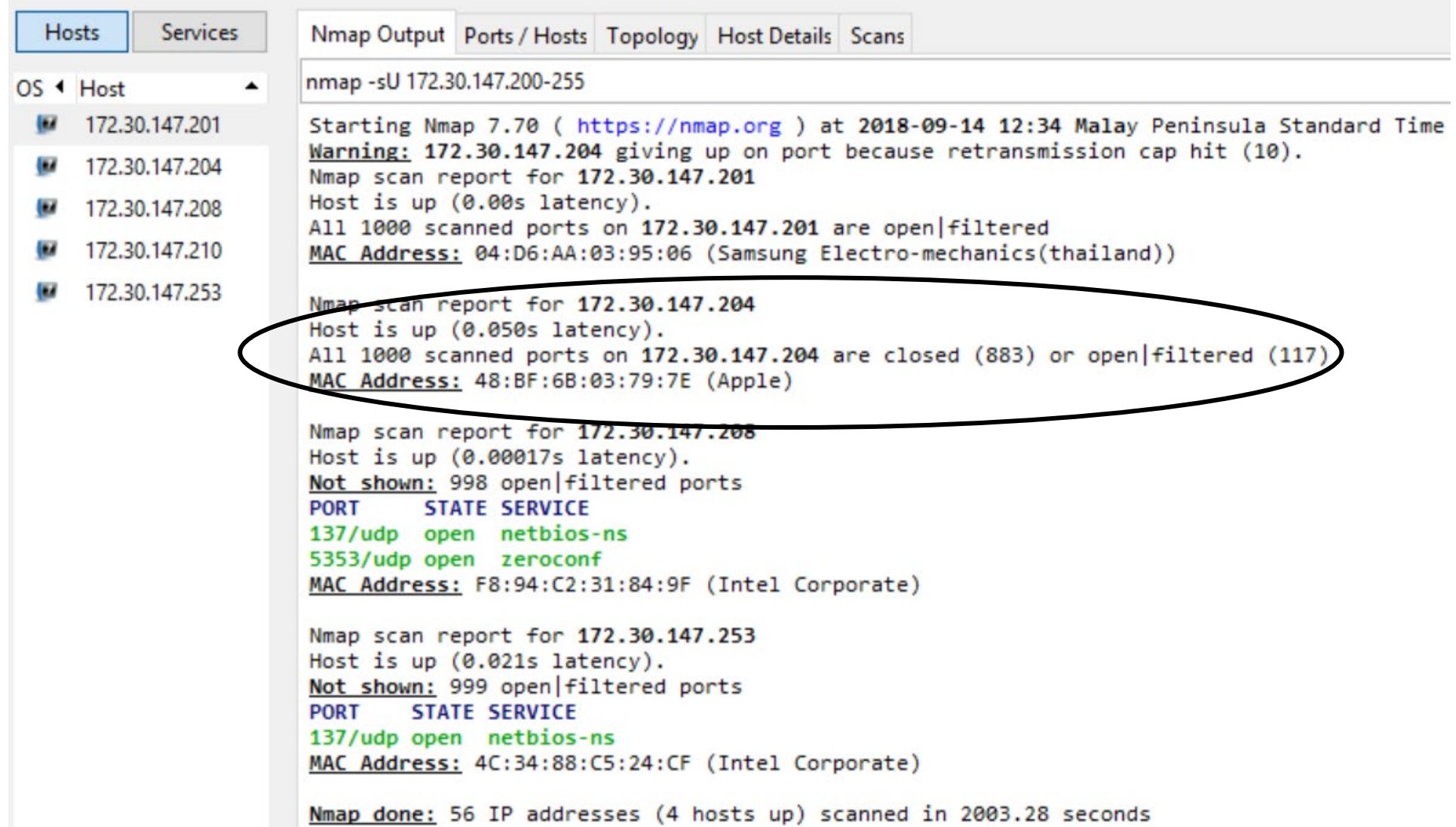
Nmap scan report for 172.27.146.249
Host is up (0.016s latency).
Not shown: 997 filtered ports
PORT      STATE SERVICE
135/tcp open  msrpc
139/tcp open  netbios-ssn
445/tcp open  microsoft-ds
MAC Address: 84:3A:4B:0B:6E:3C (Intel Corporate)

Nmap scan report for 172.27.146.252
Host is up (0.0020s latency).
Not shown: 996 filtered ports
PORT      STATE SERVICE
135/tcp open  msrpc
139/tcp open  netbios-ssn
445/tcp open  microsoft-ds
49155/tcp open unknown
MAC Address: 7C:7A:91:45:75:9F (Intel Corporate)

Nmap scan report for 172.27.146.254
Host is up (0.000077s latency).
Not shown: 999 filtered ports
PORT      STATE SERVICE
135/tcp open  msrpc
MAC Address: 5C:C5:D4:8E:18:5E (Intel Corporate)

Nmap done: 45 IP addresses (18 hosts up) scanned in 172.60 seconds
  
```

UDP Sweep vs TCP Sweep Demo – 2/3



Hosts Services

OS Host

- 172.30.147.201
- 172.30.147.204
- 172.30.147.208
- 172.30.147.210
- 172.30.147.253

Nmap Output Ports / Hosts Topology Host Details Scans

nmap -sU 172.30.147.200-255

Starting Nmap 7.70 (<https://nmap.org>) at 2018-09-14 12:34 Malay Peninsula Standard Time
Warning: 172.30.147.204 giving up on port because retransmission cap hit (10).
Nmap scan report for 172.30.147.201
Host is up (0.00s latency).
All 1000 scanned ports on 172.30.147.201 are open|filtered
MAC Address: 04:D6:AA:03:95:06 (Samsung Electro-mechanics(thailand))

Nmap scan report for 172.30.147.204
Host is up (0.050s latency).
All 1000 scanned ports on 172.30.147.204 are closed (883) or open|filtered (117)
MAC Address: 48:BF:6B:03:79:7E (Apple)

Nmap scan report for 172.30.147.208
Host is up (0.00017s latency).
Not shown: 998 open|filtered ports
PORT STATE SERVICE
137/udp open netbios-ns
5353/udp open zeroconf
MAC Address: F8:94:C2:31:84:9F (Intel Corporate)

Nmap scan report for 172.30.147.253
Host is up (0.021s latency).
Not shown: 999 open|filtered ports
PORT STATE SERVICE
137/udp open netbios-ns
MAC Address: 4C:34:88:C5:24:CF (Intel Corporate)

Nmap done: 56 IP addresses (4 hosts up) scanned in 2003.28 seconds

UDP Sweep vs TCP Sweep Demo – 3/3

```
OS Host
172.30.147.201
172.30.147.204
172.30.147.208
172.30.147.210
172.30.147.231
172.30.147.253
```

```
nmap -sS 172.30.147.200-255

Nmap scan report for 172.30.147.201
Host is up (0.040s latency).
All 1000 scanned ports on 172.30.147.201 are filtered (828) or closed (172)
MAC Address: 04:D6:AA:03:95:06 (Samsung Electro-mechanics(thailand))

Nmap scan report for 172.30.147.204
Host is up (0.024s latency).
Not shown: 999 closed ports
PORT      STATE SERVICE
62078/tcp  open  iphone-sync
MAC Address: 48:BF:6B:03:79:7E (Apple)

Nmap scan report for 172.30.147.208
Host is up (0.000083s latency).
Not shown: 997 filtered ports
PORT      STATE SERVICE
3580/tcp  open  nati-svrloc
8000/tcp  open  http-alt
8080/tcp  open  http-proxy
MAC Address: F8:94:C2:31:84:9F (Intel Corporate)

Nmap scan report for 172.30.147.231
Host is up (0.000016s latency).
All 1000 scanned ports on 172.30.147.231 are closed
MAC Address: EC:1F:72:98:FC:FB (Samsung Electro-mechanics(thailand))

Nmap scan report for 172.30.147.253
Host is up (0.0098s latency).
Not shown: 996 filtered ports
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
2869/tcp  open  icslap
MAC Address: 4C:34:88:C5:24:CF (Intel Corporate)
```

UDP Sweep vs TCP Sweep

Aspect	TCP Sweep	UDP Sweep
Protocol	TCP	UDP
Connection-oriented?	Yes	No
Typical response	TCP SYN/ACK or RST	UDP response, or ICMP Port Unreachable
Reliability	Generally easier to determine	More difficult
Speed	Usually faster	Usually slower
Firewall behaviour	Often filtered by firewalls	Frequently filtered/rate-limited
Common use	Discover TCP services/ports	Discover UDP services/ports
Examples	HTTP 80, HTTPS 443, SSH 22	DNS 53, DHCP 67/68, NTP 123, SNMP 161
Nmap option	-sT / -sS	-sU

UDP Sweep – KALI LINUX Demo 1

```
root@kali2204:~# service postgresql start
root@kali2204:~# ss -lntp | grep post
LISTEN      0            128          127.0.0.1:5432
    users: ( ("postgres",pid=5277,fd=6))
LISTEN      0            128          :::1:5432
    users: ( ("postgres",pid=5277,fd=3))
root@kali2204:~#
```

Payload caught by AV? Fly under the radar with Dynamic Payloads in Metasploit Pro -- learn more on <http://rapid7.com/metasploit>

```

      =[ metasploit v4.14.10-dev ]
+ -- --=[ 1639 exploits - 944 auxiliary - 289 post ]
+ -- --=[ 472 payloads - 40 encoders - 9 nops ]
+ -- --=[ Free Metasploit Pro trial: http://r-7.co/trymsp ]

```

```
root@kali2204:~# msfconsole
```

[illegible]

- Metasploit uses **PostgreSQL** as its database so it needs to be launched first
- Verify that **PostgreSQL** is running by checking the output of **ss -ant**
- Make sure that port 5432 is listening

UDP Sweep – KALI LINUX Demo 2

```
msf > service postgresql start
[*] exec: service postgresql start

msf > ss -ant
[*] exec: ss -ant
```

State	Recv-Q	Send-Q	Local Address:Port	Peer Address:Port
LISTEN	0	128	127.0.0.1:5432	*:*
LISTEN	0	128	:::1:5432	:::*
ESTAB	0	0	:::1:5432	:::1:36888
ESTAB	0	0	:::1:36888	:::1:5432
ESTAB	0	0	:::1:36886	:::1:5432
ESTAB	0	0	:::1:5432	:::1:36886

```
msf > db_status
[*] postgresql connected to msf
msf >
```

```
msf > use auxiliary/scanner/discovery/udp_sweep
msf auxiliary(udp_sweep) > show options
```

Module options (auxiliary/scanner/discovery/udp_sweep):

Name	Current Setting	Required	Description
BATCHSIZE	256	yes	The number of hosts to probe in each set
RHOSTS		yes	The target address range or CIDR identifier
THREADS	10	yes	The number of concurrent threads

UDP Sweep – KALI LINUX Demo 3

To configure this module, we need to set the RHOSTS and THREADS values and run it

```
msf auxiliary(udp_sweep) > set RHOSTS 137.132.21.1-10
RHOSTS => 137.132.21.1-10
msf auxiliary(udp_sweep) > set THREADS 10
THREADS => 10
msf auxiliary(udp_sweep) > run

[*] Sending 13 probes to 137.132.21.1->137.132.21.10 (10 hosts)
[*] Scanned 10 of 10 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(udp_sweep) > █
```

```
msf auxiliary(udp_sweep) > set RHOSTS 202.94.70.1-254
RHOSTS => 202.94.70.1-254
msf auxiliary(udp_sweep) > set THREADS 254
THREADS => 254
msf auxiliary(udp_sweep) > run

[*] Sending 13 probes to 202.94.70.1->202.94.70.254 (254 hosts)
[*] Discovered NTP on 202.94.70.1:123 (NTP v4 (unsynchronized))
[*] Discovered DNS on 202.94.70.2:53 (0a218523000100000000000000756455253494f4e0442494e440000100003)
[*] Discovered DNS on 202.94.70.254:53 (40058500000100010001000000756455253494f4e0442494e440000100003c00c001000030000000000005046e6f6e650776657273696f6e0462696e6400000200030000000002c02f)
[*] Scanned 254 of 254 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(udp_sweep) > █
```

Common TCP / UDP ports

TCP Port Number	Description
21	File Transfer Protocol (FTP)
22	Secure Shell (SSH)
23	Telnet
25	SMTP
80	HTTP

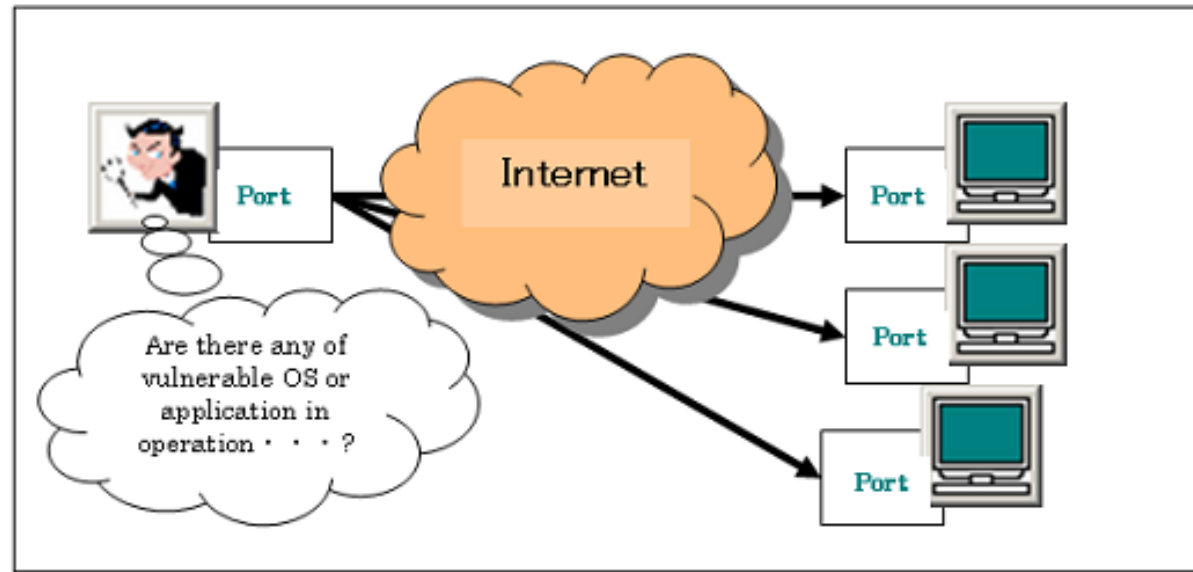
UDP Port Number	Description
53	DNS Queries
69	Trivial File Transfer Protocol
137	NetBIOS name service
138	NetBIOS datagram service
161	SNMP

Summary

- Scanning and Enumeration
 - 2nd Stage of Ethical Hacking
 - Footprinting is more of Reconnaissance
 - Scanning comprises: Ping Sweeps and Port Scans
- Ping Sweeps (ICMP requests may be dropped)
 - Ping (ICMP) sweeps – Echo and Non Echo
 - DNSmap (Kali Linux) - Subdomains
 - Tools – Zenmap (Nmap with GUI), Angry IP Scanner
 - TCP and UDP sweeps (when ICMP requests blocked)
- TCP Sweeps – depends on OS, may be spoofed by firewall
- UDP Sweeps – unreliable; info from negative reply
- **Next Session – Port Scanning**

PORT SCANNING

Introduction to TCP Port Scanning



- Goal to find out **open**, **closed** and **filtered** ports (filtered means no reply from the remote host)
- **Open** remote port: send SYN, host responds with SYN ACK
- **Closed** remote port: send SYN, host responds with RST ACK
- **Filtered** remote port: send SYN, host may not respond
- Attacker's other goal is to find port(s) with services vulnerable to different security-related exploits (Enumeration)

Nmap Demo – Selective Port Scan

```
OS Host
172.27.146.1
172.27.146.2
172.27.146.4
172.27.146.8
172.27.146.9
172.27.146.10
172.27.146.11
```

```
nmap -p 101-200 172.27.146.8

Starting Nmap 7.12 ( https://nmap.org ) at 2016-09-16
16:02 Malay Peninsula Standard Time
Nmap scan report for 172.27.146.8
Host is up (0.037s latency).
Not shown: 98 filtered ports
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
MAC Address: 4C:34:88:C5:2E:B0 (Intel Corporate)
```

```
OS Host
172.27.146.1
172.27.146.2
172.27.146.4
172.27.146.8
172.27.146.9
172.27.146.10
172.27.146.11
172.27.146.13
172.27.146.14
172.27.146.16
172.27.146.18
172.27.146.20
172.27.146.234
172.27.146.252
```

```
nmap -p 101-200 172.27.146.14

Starting Nmap 7.12 ( https://nmap.org ) at 2016-09-16
16:04 Malay Peninsula Standard Time
Nmap scan report for 172.27.146.14
Host is up (0.0082s latency).
Not shown: 83 closed ports
PORT      STATE SERVICE
106/tcp    filtered pop3pw
126/tcp    filtered unknown
130/tcp    filtered cisco-fna
138/tcp    filtered netbios-dgm
142/tcp    filtered bl-idm
145/tcp    filtered unknown
147/tcp    filtered unknown
155/tcp    filtered unknown
158/tcp    filtered pcmail-srv
169/tcp    filtered unknown
170/tcp    filtered unknown
171/tcp    filtered unknown
173/tcp    filtered xyplex-mux
174/tcp    filtered mailq
177/tcp    filtered xdmcp
184/tcp    filtered ocserver
200/tcp    filtered src
MAC Address: 5C:AD:CF:1D:CA:18 (Apple)

Nmap done: 1 IP address (1 host up) scanned in 14.76
seconds
```

Default is
SYN SCAN

nmap -p <port range>
IP address

```
nmap -p 1-100 172.27.146.30

Starting Nmap 7.12 ( https://nmap.org ) at 2016-09-16
16:11 Malay Peninsula Standard Time
Nmap scan report for 172.27.146.30
Host is up (0.0082s latency).
Not shown: 77 filtered ports
PORT      STATE SERVICE
3/tcp     closed compressnet
10/tcp    closed unknown
13/tcp    closed daytime
14/tcp    closed unknown
17/tcp    closed qotd
26/tcp    closed rsftp
27/tcp    closed nsw-fe
32/tcp    closed unknown
39/tcp    closed unknown
40/tcp    closed unknown
41/tcp    closed unknown
42/tcp    closed nameserver
48/tcp    closed auditd
49/tcp    closed tacacs
51/tcp    closed la-maint
68/tcp    closed dhcpd
75/tcp    closed priv-dial
85/tcp    closed mit-ml-dev
94/tcp    closed objcall
95/tcp    closed supdup
96/tcp    closed dixie
99/tcp    closed metagram
100/tcp   closed newacct
MAC Address: 10:41:7F:B4:5D:3B (Apple)

Nmap done: 1 IP address (1 host up) scanned in 11.3:
seconds
```

TCP Specs for Port Scan

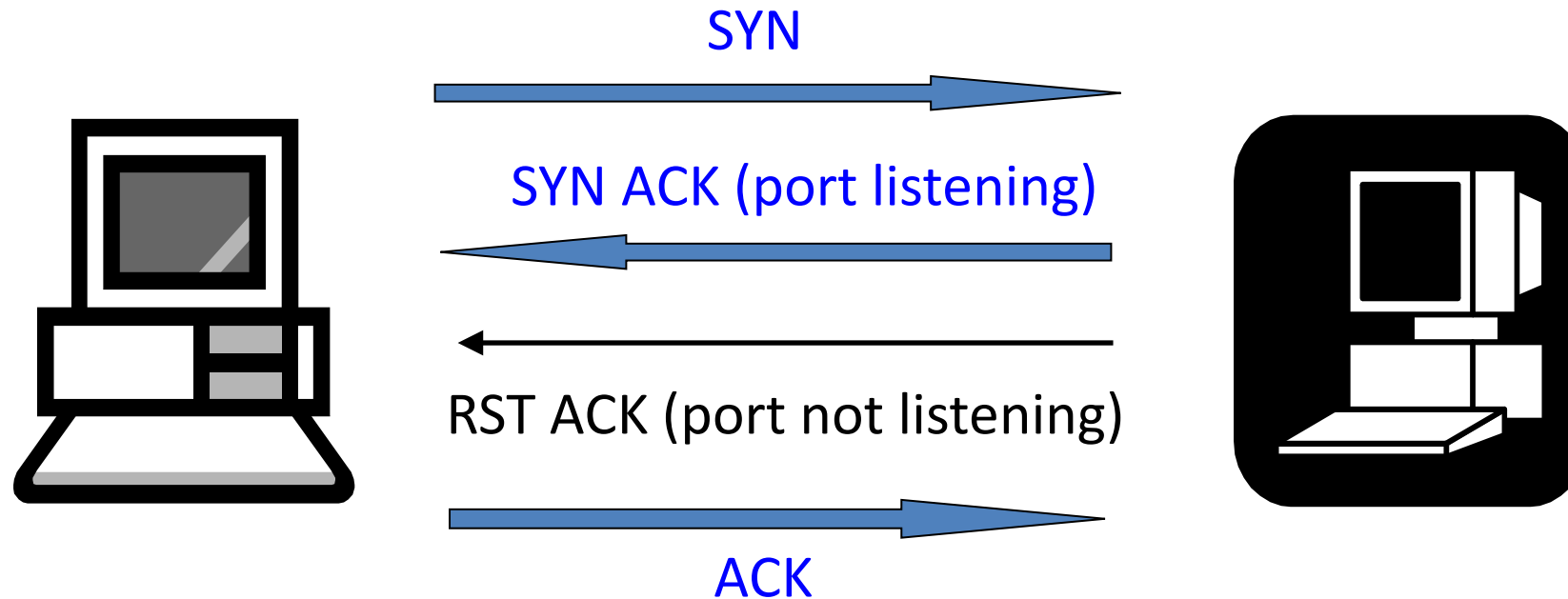
- Port Scanning via TCP adheres to:
 - RFC 793 - a protocol specification that defines how TCP should react to FIN, ACK, and SYN packets
 - According to RFC 793 ***open ports*** are required to reply with an **ACK** packet, ***closed ports*** are required to reply with a **RESET** packet to our probe packets, while ***filtered ports*** must ignore any packet in question
 - Unfortunately, not all systems adhere fully to RFC 793 - a number of systems send RST responses to the probes regardless of whether the port is open or not

Port Scanning Techniques



- TCP Connect() Scan – most basic form
- TCP SYN Scan(Half-Open Scan) – don't establish full TCP connection
- TCP FIN Scan – Stealth Scan
- Advanced Scanning Techniques

TCP Connect() Scan



- Also known as Vanilla scan
- If port is reachable, connect to it for further probing
- `nmap -sT -p`

Pros and Cons of TCP Connect() Scan

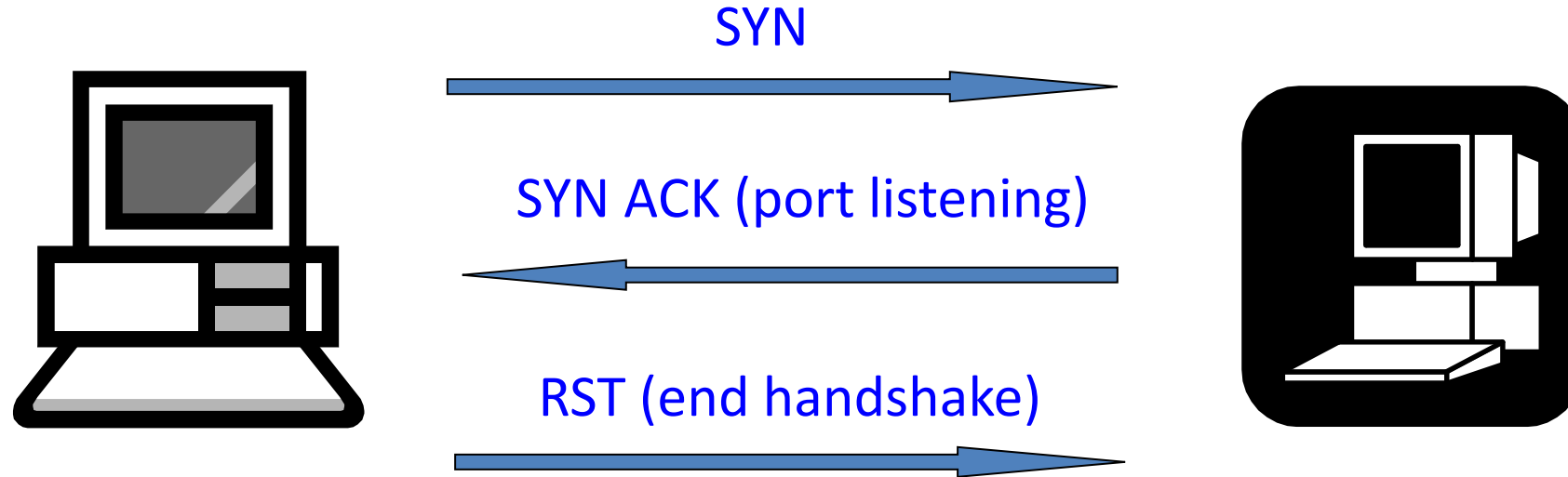
PROS:

- No special privileges are required to run the TCP connect() scan
- Accurate in determining TCP services
- Can distinguish among open, closed and filtered (open port focus)

CONS:

- Time-Consuming (scanning speed is slow)
- This kind of scan is easily detected by IDS / IPS (noisy, involves many packets)
- Inspecting the target's log will show a number of connections and error messages immediately after each one of them was initiated

TCP SYN Scan (Half-Open Scan)



Why is this called Half-Open Scan?

We immediately tear down the connection by sending an RST but port remains open (nmap -sS)

What happens when port is closed?

If port is closed, host will respond with an RST ACK.

If no response is received after several retransmissions, the port is marked as filtered.

Pros and Cons of TCP SYN Scan

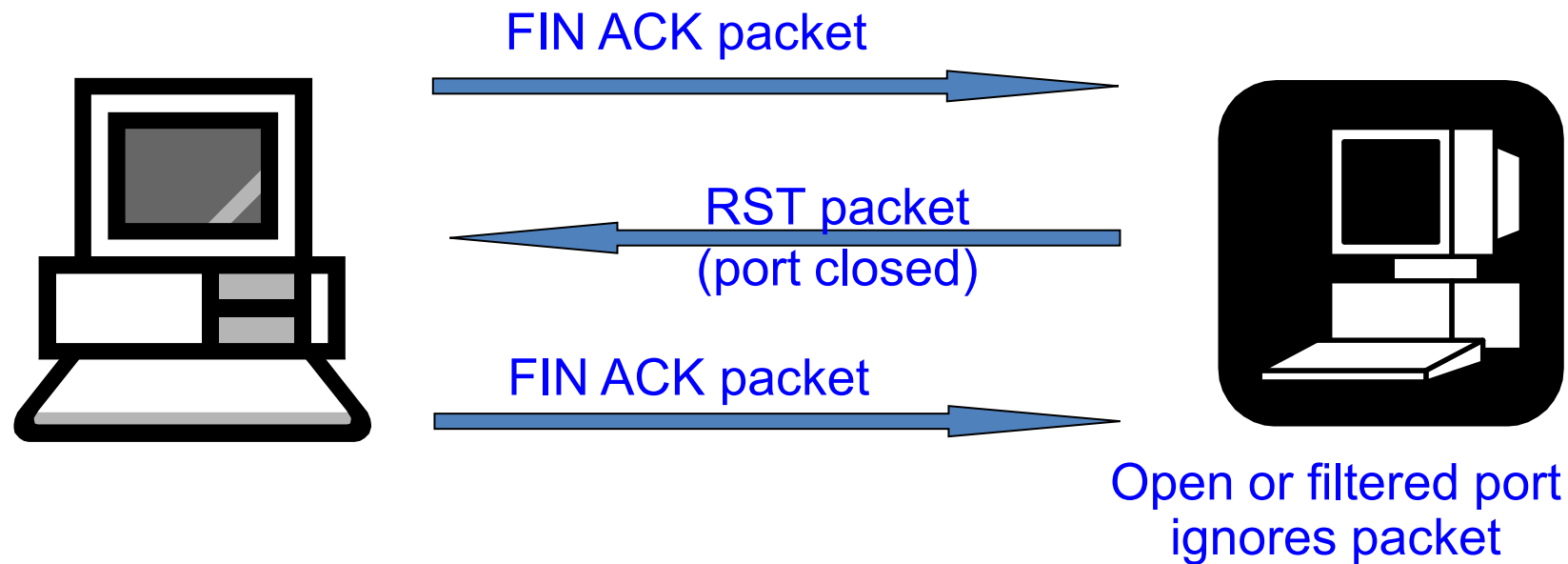
PROS:

- Faster than TCP Connect Scan
- Stealthy - most target hosts do not log such scan attempts
- Able to differentiate among open, closed and filtered ports

CONS:

- Requires privileged access (root or admin)
- Some firewalls and packet filters watch for SYNs to restricted ports (e.g. Barracuda, Checkpoint)

TCP FIN Scan - Stealth Scan

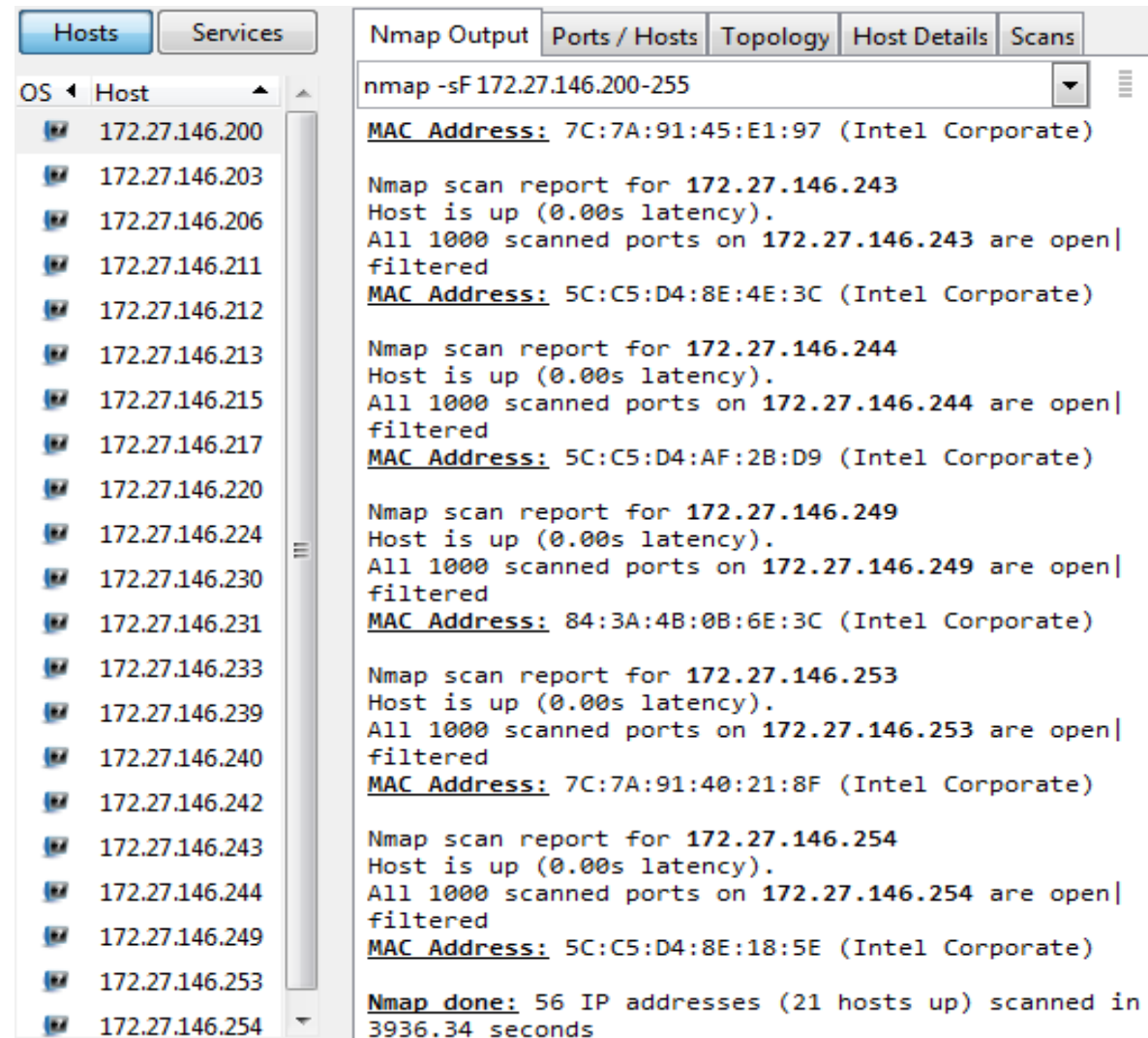


Scans for closed ports (nmap -sF -p)

Why is FIN Scan considered stealthy?

TCP FIN Scan Demo

Used for avoiding
firewalls



The screenshot displays the Nmap GUI interface. On the left, the 'Hosts' tab is active, showing a list of scanned IP addresses from 172.27.146.200 to 172.27.146.254. On the right, the 'Nmap Output' tab is selected, showing the command 'nmap -sF 172.27.146.200-255' and the resulting scan reports for several hosts. Each report indicates that the host is up and that all 1000 scanned ports are open or filtered. The MAC addresses for the hosts are listed as belonging to Intel Corporate.

Hosts | **Services**

OS Host

- 172.27.146.200
- 172.27.146.203
- 172.27.146.206
- 172.27.146.211
- 172.27.146.212
- 172.27.146.213
- 172.27.146.215
- 172.27.146.217
- 172.27.146.220
- 172.27.146.224
- 172.27.146.230
- 172.27.146.231
- 172.27.146.233
- 172.27.146.239
- 172.27.146.240
- 172.27.146.242
- 172.27.146.243
- 172.27.146.244
- 172.27.146.249
- 172.27.146.253
- 172.27.146.254

Nmap Output | **Ports / Hosts** | **Topology** | **Host Details** | **Scans**

nmap -sF 172.27.146.200-255

MAC Address: 7C:7A:91:45:E1:97 (Intel Corporate)

Nmap scan report for 172.27.146.243
Host is up (0.00s latency).
All 1000 scanned ports on 172.27.146.243 are open|filtered
MAC Address: 5C:C5:D4:8E:4E:3C (Intel Corporate)

Nmap scan report for 172.27.146.244
Host is up (0.00s latency).
All 1000 scanned ports on 172.27.146.244 are open|filtered
MAC Address: 5C:C5:D4:AF:2B:D9 (Intel Corporate)

Nmap scan report for 172.27.146.249
Host is up (0.00s latency).
All 1000 scanned ports on 172.27.146.249 are open|filtered
MAC Address: 84:3A:4B:0B:6E:3C (Intel Corporate)

Nmap scan report for 172.27.146.253
Host is up (0.00s latency).
All 1000 scanned ports on 172.27.146.253 are open|filtered
MAC Address: 7C:7A:91:40:21:8F (Intel Corporate)

Nmap scan report for 172.27.146.254
Host is up (0.00s latency).
All 1000 scanned ports on 172.27.146.254 are open|filtered
MAC Address: 5C:C5:D4:8E:18:5E (Intel Corporate)

Nmap done: 56 IP addresses (21 hosts up) scanned in 3936.34 seconds

Pros and Cons of TCP FIN Scan

PROS:

- Fast
- Stealthy – very few packets (one packet each time, no connection established)

CONS:

- Cannot differentiate between open and filtered ports (both incur no response – **how does this differ from Half-Open Scan?**)
- Require special privileges (e.g., root on Unix and Linux systems)

Vulnerable Security Product: Norton Personal Firewall

ADVANCED SCANNING

Advanced Port Scanning Techniques

Random Scan

Randomizing the sequence of targets and ports probed as well as scanning intervals may prevent detection.

Slow Scan

Some hackers are very patient and can use network scanners that spread out the scan over a long period of time. The scan rate can be, for example, as low as 2 packets per day per target site. Can bypass several IDS: eg. Snort, Bro

Fragmentation Scan

In case of TCP the 8 bytes of data (minimum fragment size) are enough to contain the source and destination port numbers. This will force the TCP flags field into the second fragment. May hide scan from some firewalls and IDSs.

Decoy Scan

Some network scanners include options for *decoys* or spoofed addresses in their attacks. If many decoys are used, determining who the real attacker is, will be nearly impossible

Coordinated Scan

Group scanning based on a strategy or plan

Fragmentation Scan

- All IP packets that carry data can be fragmented
- Split probe packet into several IP fragments
- Some firewalls and IDSs may incorrectly reassemble or completely miss portions of the scan. They may assume that this was just another segment of traffic that has already passed through their access list.
- Advantage: difficult to detect scan
- Disadvantage: may not work on all OSs; may crash some firewalls and IDSs
- **nmap -f (experiment and observe in the lab)**

```
root@bt:~# nmap -f 192.168.1.64

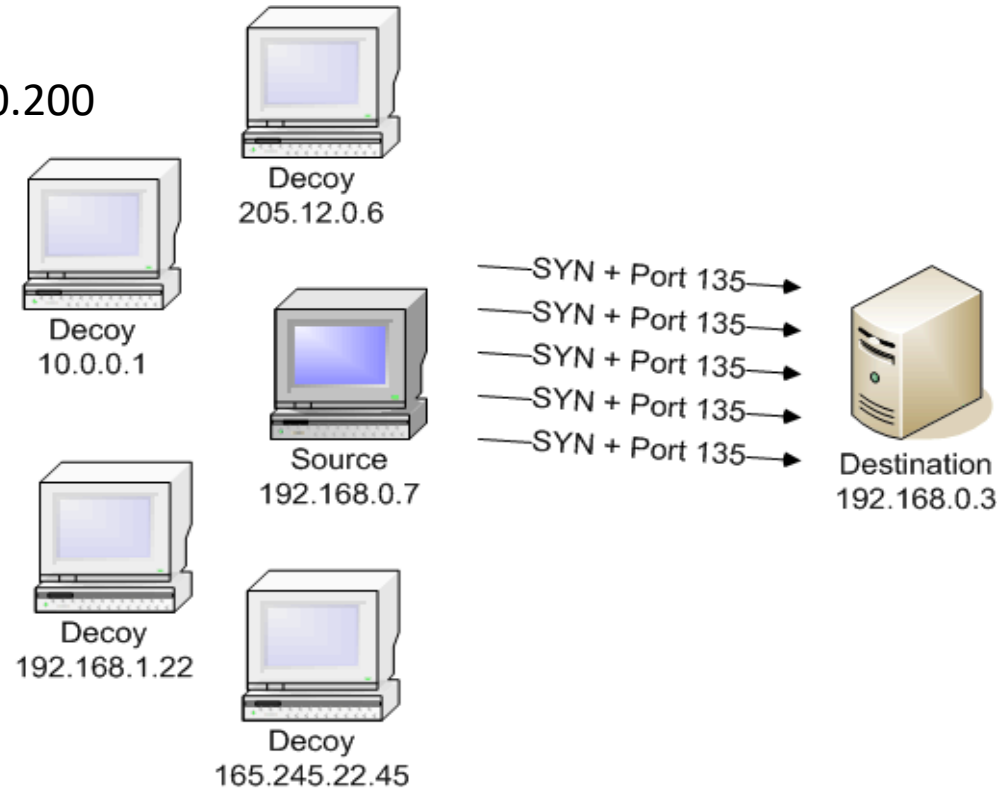
Starting Nmap 5.61TEST4 ( http://nmap.org ) at 2012-04-02 13:56 BST
Nmap scan report for Blackbox.home (192.168.1.64)
Host is up (0.00049s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
902/tcp    open  iss-realsecure
MAC Address: 00:04:4B:00:0C:87 (Nvidia)

Nmap done: 1 IP address (1 host up) scanned in 0.12 seconds
```

Decoy Scan

```
nmap -sX -D [decoy1,decoy2,...] [target]  
nmap -sX -D 192.168.1.10,192.168.1.11 172.35.10.200  
nmap -sX -D RND:5 172.35.10.200
```

Packets from real source
must contain the actual
source address or else the
response from the target
system will not be received



- Used to confuse the target
- Send spoofed probe packets with fake source address(es) to target (one must be real)
- More difficult to determine the actual scanner
- More decoys – slower scanning
- **nmap -sX -D (experiment and observe in the lab; X can be S or T etc.)**

Decoy Scan – KALI LINUX Demo

```

root@kali2204:~# nmap -sT 202.94.70.1-1037D 202.94.70.100,192.168.248.250,192.168.248.1
28] Scanned 10 of 10 hosts (100% complete)
[*] Auxiliary module execution completed
Starting Nmap (7.40 ( https://nmap.org )) at 2017-09-13 15:31 +08
Nmap scan report for 202.94.70.1
Host is up (0.011s latency)
All 1000 scanned ports on 202.94.70.1 are filtered
msf auxiliary(udp_sweep) > run
Nmap scan report for 202.94.70.2
Host is up (0.012s latency)
Not shown: 9994 filtered ports (100% complete)
PORT STATE SERVICE
53/tcp open domain
msf auxiliary(udp_sweep) > set RHOSTS 202.94.70.1-254
RHOSTS => 202.94.70.1-254
Nmap scan report for 202.94.70.3
Host is up (0.0099s latency).
Not shown: 999 filtered ports
PORT STATE SERVICE
80/tcp open http

```

Decoy Scan – Windows Demo

```
C:\Users\A88252>nmap -sS -D 172.27.146.97,172.27.146.111 172.27.146.220

Starting Nmap 6.47 < http://nmap.org > at 2015-07-30 11:10 Malay Peninsula Standard Time
Nmap scan report for 172.27.146.220
Host is up (0.0082s latency).
Not shown: 994 filtered ports
PORT      STATE SERVICE
80/tcp    open  http
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
443/tcp    open  https
445/tcp    open  microsoft-ds
49155/tcp  open  unknown
MAC Address: 7C:7A:91:45:E6:EC (Intel Corporate)

Nmap done: 1 IP address (1 host up) scanned in 24.06 seconds

C:\Users\A88252>nmap -sS -D 172.27.146.97 172.27.146.220

Starting Nmap 6.47 < http://nmap.org > at 2015-07-30 11:11 Malay Peninsula Standard Time
Nmap scan report for 172.27.146.220
Host is up (0.013s latency).
Not shown: 994 filtered ports
PORT      STATE SERVICE
80/tcp    open  http
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
443/tcp    open  https
445/tcp    open  microsoft-ds
49155/tcp  open  unknown
MAC Address: 7C:7A:91:45:E6:EC (Intel Corporate)

Nmap done: 1 IP address (1 host up) scanned in 17.91 seconds
```

Decoy Scan with Wireshark

nmap -D 192.168.102.125, 192.168.102.126, 192.168.102.127, 192.168.102.128, 192.168.102.129, 192.168.102.130, **192.168.102.132** 192.168.102.131



192.168.102.125	192.168.102.131	TCP	58 43052 → 1723 [SYN] Seq=0 Win=1024 Len=0 MSS=146
192.168.102.132	192.168.102.131	TCP	58 43052 → 1723 [SYN] Seq=0 Win=1024 Len=0 MSS=146
192.168.102.126	192.168.102.131	TCP	58 43052 → 1723 [SYN] Seq=0 Win=1024 Len=0 MSS=146
192.168.102.127	192.168.102.131	TCP	58 43052 → 1723 [SYN] Seq=0 Win=1024 Len=0 MSS=146
192.168.102.128	192.168.102.131	TCP	58 43052 → 1723 [SYN] Seq=0 Win=1024 Len=0 MSS=146
192.168.102.129	192.168.102.131	TCP	58 43052 → 1723 [SYN] Seq=0 Win=1024 Len=0 MSS=146
192.168.102.130	192.168.102.131	TCP	58 43052 → 1723 [SYN] Seq=0 Win=1024 Len=0 MSS=146
192.168.102.132	192.168.102.131	TCP	58 [TCP Out-of-Order] 43052 → 1723 [SYN] Seq=0 Win

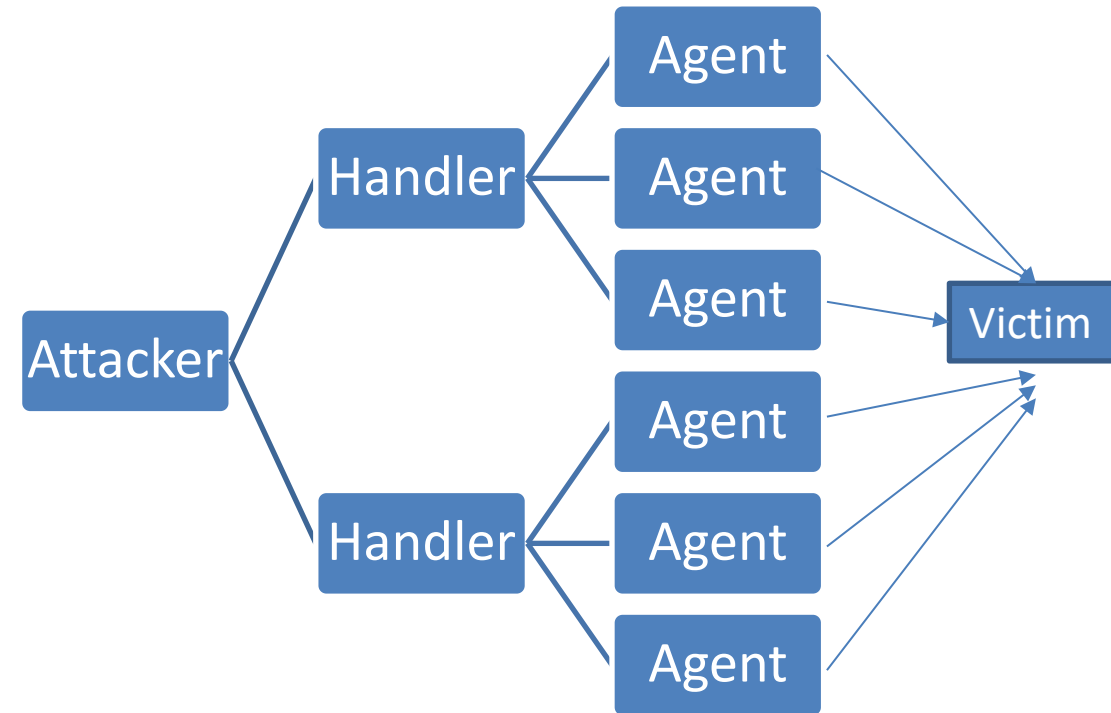
However with directive "ME": nmap -D 192.168.102.125, 192.168.102.126, 192.168.102.127, 192.168.102.128, 192.168.102.129, 192.168.102.130, **ME** 192.168.102.131



192.168.102.125	192.168.102.131	TCP	58 56376 → 139 [SYN] Seq=0 Win=1024
192.168.102.126	192.168.102.131	TCP	58 56376 → 139 [SYN] Seq=0 Win=1024
192.168.102.127	192.168.102.131	TCP	58 56376 → 139 [SYN] Seq=0 Win=1024
192.168.102.128	192.168.102.131	TCP	58 56376 → 139 [SYN] Seq=0 Win=1024
192.168.102.129	192.168.102.131	TCP	58 56376 → 139 [SYN] Seq=0 Win=1024
192.168.102.130	192.168.102.131	TCP	58 56376 → 139 [SYN] Seq=0 Win=1024
192.168.102.132	192.168.102.131	TCP	58 56376 → 139 [SYN] Seq=0 Win=1024

Coordinated Scan

- When a group of attackers are working together to achieve a common goal, e.g. get unauthorized access to a targeted network
- Coordinated attacks can be used to target a single host or even an entire network
- Coordinated scan can gather host information for further attack more efficiently and stealthily than single-source port scans by distributing tasks amongst multiple sources
- If multiple IPs probe a target network, each probes a certain service on a certain machine in a different time period, and therefore it would be nearly impossible to detect these scans

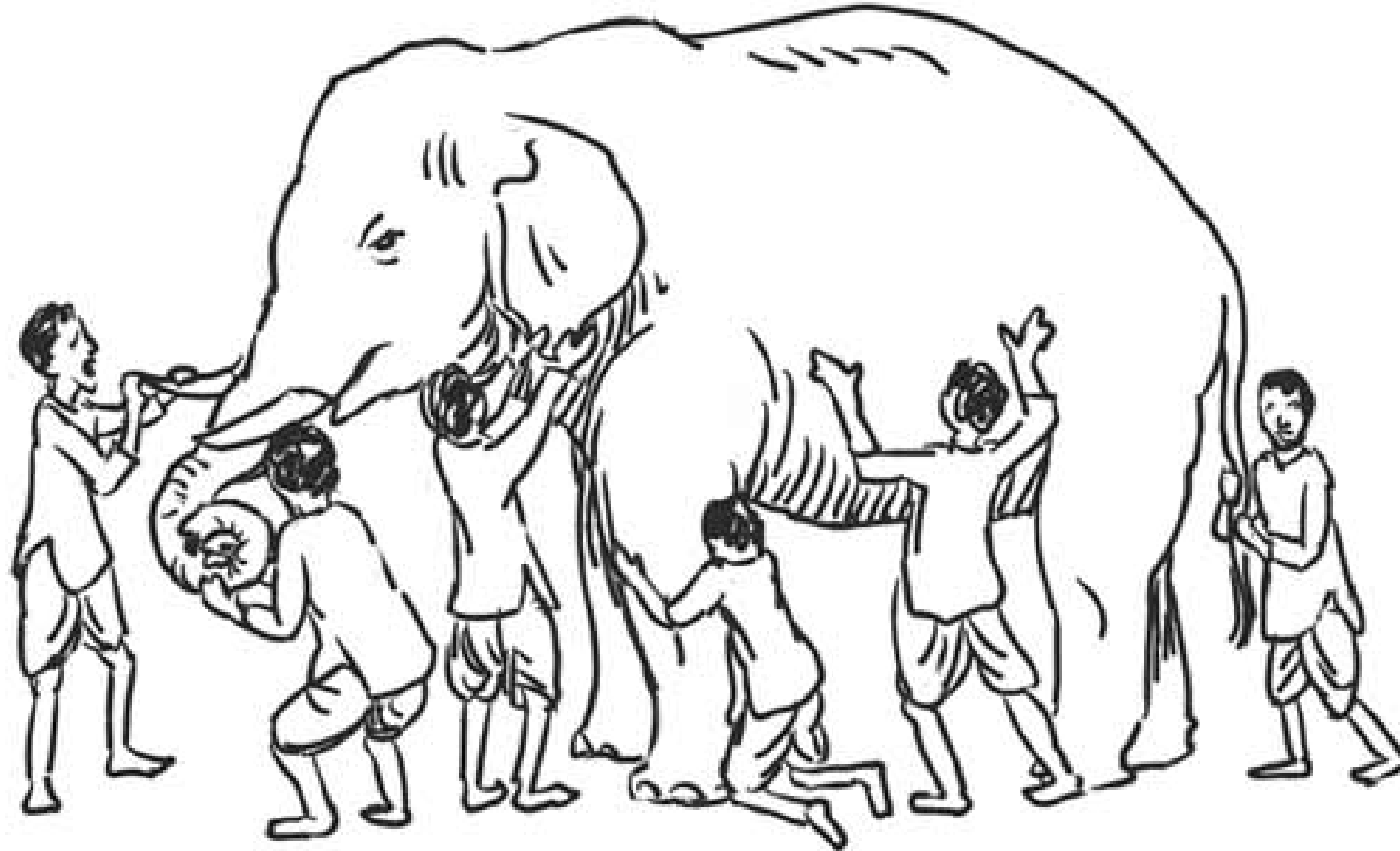


Detection Possibility: Using Smart Analytics (ML) with HoneyNet

ROUTE TRACING

After Port Scanning ...

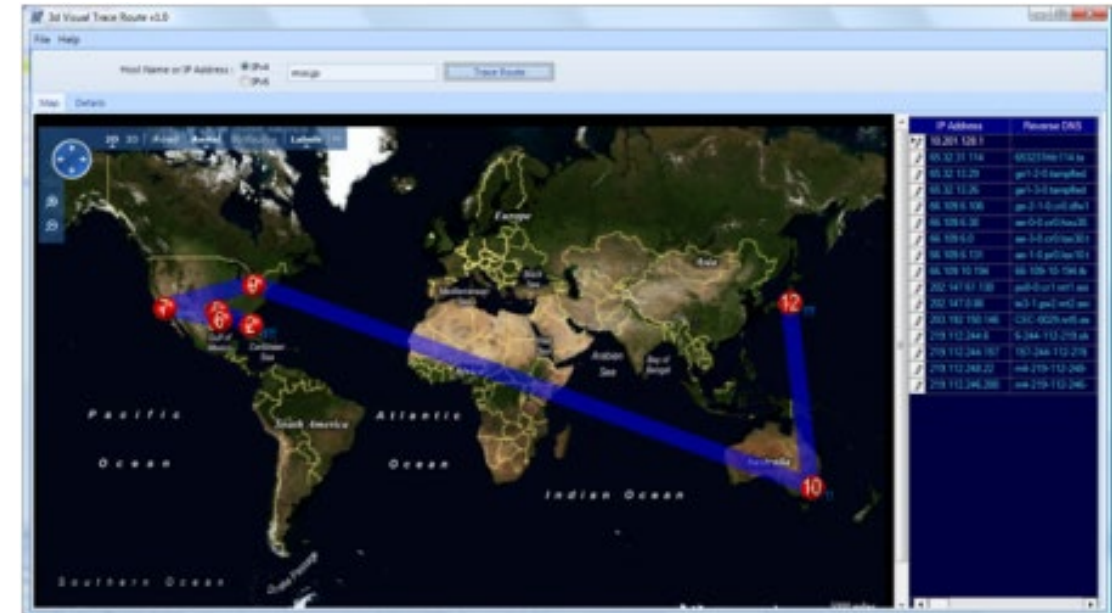
Especially when target is a networked system



Attacker has to move sideways (laterally) through a network to map system and eventually locate primary target

Introduction to Route Tracing

- List routers and hops between the client and a remote host
- The IP address and domain name (if there is one) of each router is returned to the client
- May also calculate and display the hop time
- Info may be useful to locate new potential attack vectors
- Popular trace routing tool:
 - Linux and Unix OSs - **traceroute**
 - Windows (DOS Command) – **tracert**



Trace route – KALI LINUX Demo

```
root@kali2204:~# traceroute -T sutd.edu.sg
traceroute to sutd.edu.sg (202.94.70.56), 30 hops max, 60 byte packets
 1 gateway (192.168.248.2) 0.091 ms 0.070 ms 0.067 ms
 2 www.sutd.edu.sg (202.94.70.56) 12.271 ms 10.974 ms 12.222 ms
root@kali2204:~# traceroute -T nus.edu.sg
traceroute to nus.edu.sg (137.132.21.27), 30 hops max, 60 byte packets
 1 gateway (192.168.248.2) 0.092 ms 0.071 ms 0.067 ms
 2 ddu.nus.edu.sg (137.132.21.27) 41.139 ms 41.704 ms 41.722 ms
root@kali2204:~# traceroute -T ntu.edu.sg
traceroute to ntu.edu.sg (155.69.7.173), 30 hops max, 60 byte packets
 1 gateway (192.168.248.2) 0.122 ms 0.071 ms 0.068 ms
 2 155.69.7.173 (155.69.7.173) 18.318 ms 22.629 ms 22.461 ms
root@kali2204:~# traceroute -T smu.edu.sg
traceroute to smu.edu.sg (45.64.64.148), 30 hops max, 60 byte packets
 1 gateway (192.168.248.2) 0.093 ms 0.069 ms 0.067 ms
 2 45.64.64.148 (45.64.64.148) 86.219 ms 85.367 ms 84.541 ms
root@kali2204:~#
```

It's possible that your network blocks ICMP traffic. Try using traceroute -T to use TCP rather than ICMP.

Tracert Command Syntax

TRACERT syntax:

```
tracert [-d] [-h maximum_hops] [-j host-list] [-w timeout] target_name
```

Parameters:

`-d`
Specifies to not resolve addresses to host names.

`-h maximum_hops` **Default = 30**
Specifies the maximum number of hops to search for target.

`-j host-list` **up to 9 routers between nodes**
Specifies loose source route along the host-list.

`-w timeout` **Default = 4000**
Waits the number of milliseconds specified by timeout for each reply.

`target_name`
Name or IP address of the target host.

`tracert -j 192.168.1.5 10.0.0.1 google.com`
→ force the packets to go through the routers at 192.168.1.5 and 10.0.0.1 before finally heading out to google.com

Trace route – Windows Demo

```
C:\Users\A88252>tracert www.sutd.edu.sg

Tracing route to www.wip.sutd.edu.sg [202.94.70.56]
over a maximum of 30 hops:

  1      1 ms      1 ms      2 ms      172.27.146.1
  2     21 ms      2 ms      1 ms      172.21.228.2
  3      2 ms      2 ms      1 ms      172.21.228.1
  4      1 ms      1 ms      1 ms      172.21.228.105
  5      2 ms      2 ms      2 ms      172.21.224.253
  6      2 ms      3 ms      2 ms      172.21.224.227
  7      4 ms      4 ms      5 ms      203.116.250.193
  8      5 ms      4 ms      5 ms      203.118.16.29
  9      5 ms      4 ms      4 ms      203.118.2.25
 10     16 ms      4 ms      4 ms      r41.starhub.net.sg [203.118.12.14]
 11     19 ms     20 ms     17 ms      203.116.8.106
 12     52 ms     44 ms     34 ms      www.sutd.edu.sg [202.94.70.56]

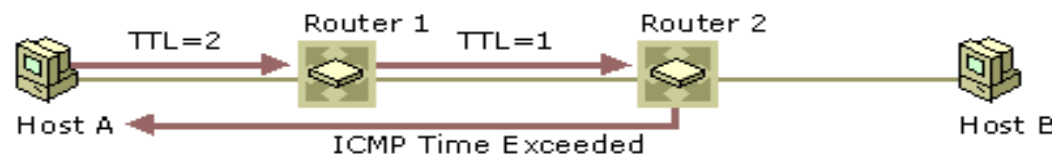
Trace complete.

C:\Users\A88252>
```

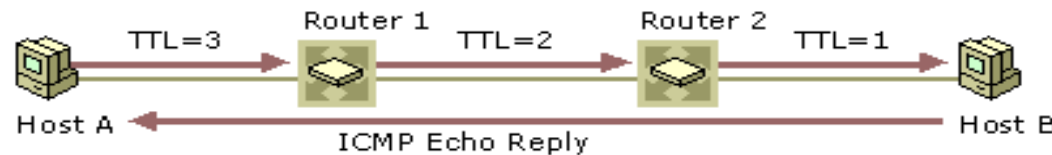
How does Tracert Work?



TTL = Hop Limit



**What if Firewall
Drops / Blocks Probes?**



- At each hop, tracert sends 3 probe packets by default and measures time (in milliseconds) of each response
- From left:

Column 1 – Hop number

Columns 2 to 4 – Round Trip Time (RTT) for 1st to 3rd probes

Column 5 – Host/router name and/or IP address

ENUMERATION

Introduction to Enumeration

- Port-based enumeration (in-depth scanning):
 - Determine OS and Services
 - Reference <http://cve.mitre.org>
- Enumeration extracts information about:
 - Shared resources (or shares) on the network
 - User account information (rarely, user authentication)
- Enumeration is more intrusive:
 - Gathered by queries via active connections to target system
- Enumeration Tools:
 - NBTScanner, NBTScan, Net View, Reaper, nmap, netcat etc.

OS Enumeration

- TCP/IP Stack Fingerprinting:
 - Send specific TCP packets to the target IP to collect configuration info
 - Compare response with nmap database of known OS fingerprints
 - OS details displayed if there is match
- Fingerprinting Technique - banner grabbing
 - acquire networked system info and port services info
- Tool and command:
 - `nmap -sV -v -n -Pn --script banner 172.27.146.242`
 - sV: Probes open ports to determine service/version info
 - v: Increase verbosity
 - n: No Reverse DNS
 - Pn: No Ping - skips the initial ping test due to modern firewalls block ping requests (ICMP)
 - script banner: Run banner grabbing script, which often reveals server software and OS.

Determine vulnerabilities to
customize exploits

Banner Grab – KALI Identify Service

```
root@kali2204:~# nmap -sS -sV -p80 -v -n -Pn --script banner sutd.edu.sg
Starting Nmap 7.40 ( https://nmap.org ) at 2017-09-13 16:10 +08
NSE: Loaded 41 scripts for scanning.
NSE: Script Pre-scanning.
Initiating NSE at 16:10
Completed NSE at 16:10, 0.00s elapsed
Initiating NSE at 16:10
Completed NSE at 16:10, 0.00s elapsed
Initiating SYN Stealth Scan at 16:10
Scanning sutd.edu.sg (202.94.70.56) [1 port]
Discovered open port 80/tcp on 202.94.70.56
Completed SYN Stealth Scan at 16:10, 0.02s elapsed (1 total ports)
Initiating Service scan at 16:10
Scanning 1 service on sutd.edu.sg (202.94.70.56)
Completed Service scan at 16:10, 6.04s elapsed (1 service on 1 host)
NSE: Script scanning 202.94.70.56.
Initiating NSE at 16:10
Completed NSE at 16:11, 15.02s elapsed
Initiating NSE at 16:11
Completed NSE at 16:11, 0.00s elapsed
Nmap scan report for sutd.edu.sg (202.94.70.56)
Host is up (0.018s latency).
PORT      STATE SERVICE VERSION
80/tcp    open  http      Microsoft IIS httpd 7.5
|_http-server-header: Microsoft-IIS/7.5
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows
```

Banner Grab – KALI Identify Service

- `nmap -sS -sV -p80 -v -n -Pn --script banner sutd.edu.sg`
 1. `nmap`: This is the Nmap command itself, used to initiate a network scan.
 2. `-sS`: This option specifies that Nmap should use a SYN scan.
 3. `-sV`: This option enables service version detection. Nmap will attempt to identify the service running on the open ports by sending additional probes to those ports to gather information about the service.
 4. `-p80`: This specifies that you want to scan port 80 on the target. Port 80 is commonly used for HTTP traffic, so you're looking for an HTTP service running on this port.
 5. `-v`: This option increases the verbosity level of the output. Using `-v` makes the output more detailed and provides additional information about the scan progress.
 6. `-n`: This option tells Nmap not to resolve hostnames to IP addresses during the scan. It will use the IP address you provided directly instead of performing DNS resolution.
 7. `-Pn`: This option tells Nmap not to perform host discovery. By default, Nmap uses host discovery techniques to determine which hosts are up before scanning. The `-Pn` option skips this step and assumes the target is up and reachable.
 8. `--script banner`: This option specifies that you want to run Nmap's "banner" script. The "banner" script is a part of Nmap's scripting engine and is used to gather banner information from open ports. It can help identify the specific software and version running on the open ports.
 9. `sutd.edu.sg`: This is the target hostname or IP address you want to scan.

Banner Grab – Zenmap Identify Service

```
nmap -sS -sV -v --script banner 172.27.147.1
```

```
Scanning 172.27.147.1 [1 port]
Completed ARP Ping Scan at 10:43, 1.26s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 10:43
Completed Parallel DNS resolution of 1 host. at 10:43, 0.00s elapsed
Initiating SYN Stealth Scan at 10:43
Scanning 172.27.147.1 [1000 ports]
Discovered open port 22/tcp on 172.27.147.1
Completed SYN Stealth Scan at 10:43, 2.16s elapsed (1000 total ports)
Initiating Service scan at 10:43
Scanning 1 service on 172.27.147.1
Completed Service scan at 10:43, 0.03s elapsed (1 service on 1 host)
NSE: Script scanning 172.27.147.1.
Initiating NSE at 10:43
Completed NSE at 10:43, 0.01s elapsed
Initiating NSE at 10:43
Completed NSE at 10:43, 0.00s elapsed
Nmap scan report for 172.27.147.1
Host is up (0.0054s latency)
Not shown: 999 closed ports
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      Cisco SSH 1.25 (protocol 2.0)
| banner: SSH-2.0-Cisco-1.25
MAC Address: B4:E9:B0:C9:A0:00 (Cisco Systems)
Service Info: OS: IOS, CPE: cpe:/o:cisco:ios

NSE: Script Post-scanning.
Initiating NSE at 10:43
Completed NSE at 10:43, 0.00s elapsed
Initiating NSE at 10:43
Completed NSE at 10:43, 0.00s elapsed
Read data files from: C:\Program Files (x86)\Nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 9.67 seconds
```

Banner Grab – Netcat Identify Service

```
C:\WINDOWS\system32>ncat -v -n 172.27.147.1  
Ncat: Version 7.70 ( https://nmap.org/ncat )  
Ncat: No connection could be made because the target machine actively refused it
```

```
C:\WINDOWS\system32>ncat -v -n 172.27.147.1 22  
Ncat: Version 7.70 ( https://nmap.org/ncat )  
Ncat: Connected to 172.27.147.1:22.  
SSH-2.0-Cisco-1.25 SSH-enabled Cisco gateway
```

- Services detected may suffer from vulnerabilities due to:
 - Misconfiguration of the service
 - Software version have security flaws
- Vulnerabilities can lead to privileged access gained by the attacker

NBTscan – Scanning Demo

```
C:\Windows\system32>nbtscan -f 172.27.146.0-254
172.27.146.13 SF\SIT-NB-X240-19 SHARING
SF <00> GROUP Domain Name
SIT-NB-X240-19 <00> UNIQUE Workstation Service
SIT-NB-X240-19 <20> UNIQUE File Server Service
SF <1e> GROUP Browser Service Elections
SF <1d> UNIQUE Master Browser
.._MSBROWSE_ <01> GROUP Master Browser
7c:7a:91:45:e2:50 ETHER SIT-NB-X240-19

172.27.146.16 SF\SIT-NB-X240-98 SHARING
SIT-NB-X240-98 <00> UNIQUE Workstation Service
SF <00> GROUP Domain Name
SIT-NB-X240-98 <20> UNIQUE File Server Service
SF <1e> GROUP Browser Service Elections
SF <1d> UNIQUE Master Browser
.._MSBROWSE_ <01> GROUP Master Browser
7c:7a:91:45:86:d4 ETHER SIT-NB-X240-98

172.27.146.21 SF\SIT-NB-X240-89 SHARING
SIT-NB-X240-89 <20> UNIQUE File Server Service
SIT-NB-X240-89 <00> UNIQUE Workstation Service
SF <00> GROUP Domain Name
SF <1e> GROUP Browser Service Elections
SF <1d> UNIQUE Master Browser
.._MSBROWSE_ <01> GROUP Master Browser
7c:7a:91:45:e4:76 ETHER SIT-NB-X240-89

172.27.146.22 \SIT-NB-MAC-012
SIT-NB-MAC-012 <00> UNIQUE Workstation Service
ac:bc:32:81:89:07 ETHER SIT-NB-MAC-012
```

```
C:\Windows\system32>nbtscan 172.27.146.0-254 : find "U="
*timeout (normal end of scan)

C:\Windows\system32>nbtscan 172.27.146.0-254 : find "EXCHANGE"
*timeout (normal end of scan)

C:\Windows\system32>nbtscan 172.27.146.0-254 : find "MAC"
172.27.146.22 \SIT-NB-MAC-012
*timeout (normal end of scan)

C:\Windows\system32>nbtscan 172.27.146.0-254 : find "IIS"
*timeout (normal end of scan)

C:\Windows\system32>nbtscan 172.27.146.0-254 : find "DC"
*timeout (normal end of scan)
```

The device named SIT-NB-X240-19 at 172.27.146.13 is actively providing workstation and file server services and is serving as the Master Browser in the network

```
SIT-Q704-79 <00> UNIQUE Workstation Service
SF <00> GROUP Domain Name
SF <1e> GROUP Browser Service Elections
SF <1d> UNIQUE Master Browser
.._MSBROWSE_ <01> GROUP Master Browser
f8:16:54:10:2f:39 ETHER SIT-Q704-79

172.27.146.109 SF\SIT-NB-X240-39 SHARING
SIT-NB-X240-39 <00> UNIQUE Workstation Service
SF <00> GROUP Domain Name
SIT-NB-X240-39 <20> UNIQUE File Server Service
SF <1e> GROUP Browser Service Elections
SF <1d> UNIQUE Master Browser
.._MSBROWSE_ <01> GROUP Master Browser
7c:7a:91:45:89:8b ETHER SIT-NB-X240-39

172.27.146.103 WORKGROUP\DANNY SHARING
DANNY <20> UNIQUE File Server Service
DANNY <00> UNIQUE Workstation Service
WORKGROUP <00> GROUP Domain Name
WORKGROUP <1e> GROUP Browser Service Elections
WORKGROUP <1d> UNIQUE Master Browser
.._MSBROWSE_ <01> GROUP Master Browser
b8:ee:65:ac:61:ef ETHER DANNY
```

- NETBIOS nameserver scanner
- nbtscan -f 172.27.146.0-254
- Hex code and type identify service being offered

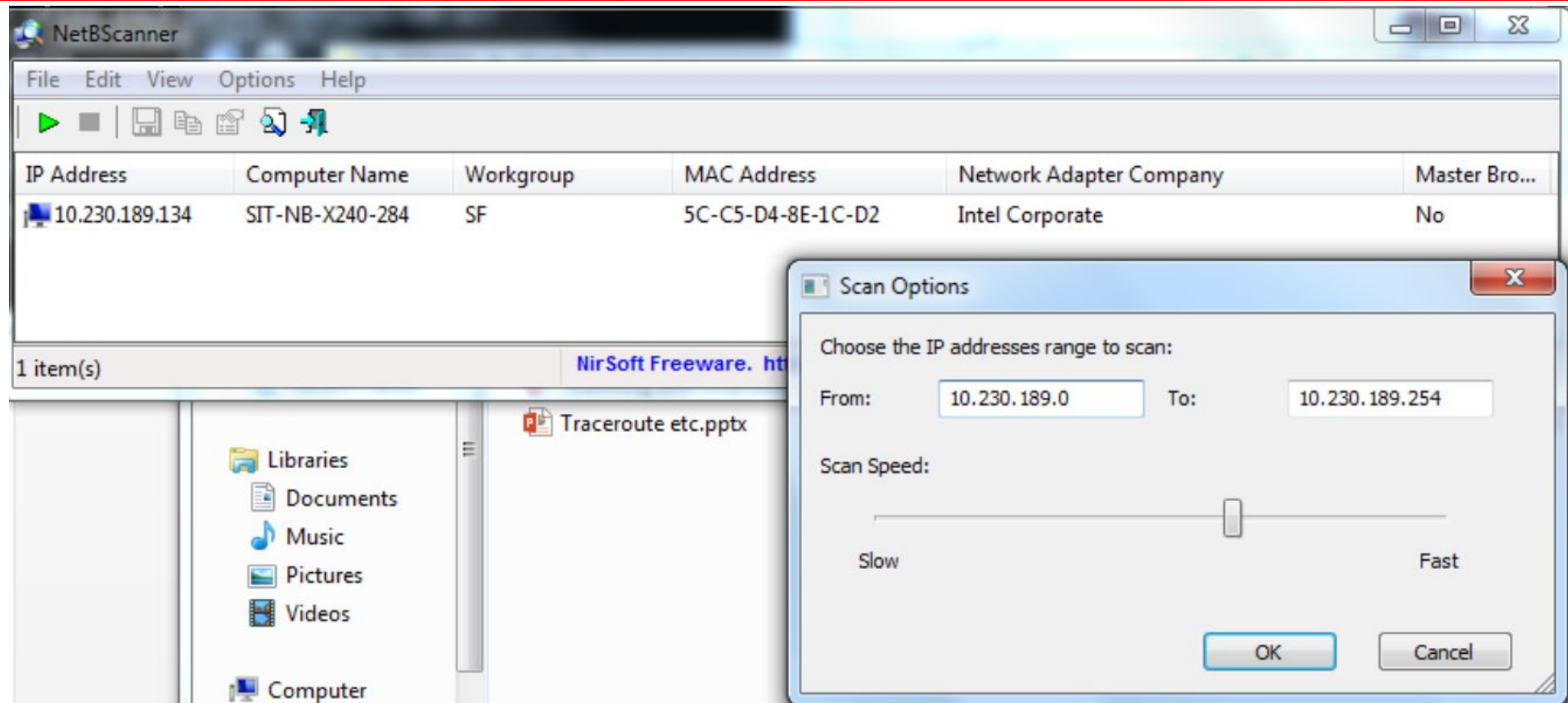
NBTscan - Guide

```
C:\> nbtscan 192.168.1.0/24
192.168.1.3      MTNDEW\WINDEV      SHARING DC
192.168.1.5      MTNDEW\TESTING
192.168.1.9      MTNDEW\WIZ         SHARING U=STEVE
192.168.1.99     MTNDEW\XPDEV       SHARING
```

Token	Meaning
SHARING	The machine in question is running the file and print sharing service, but this does <i>not</i> necessarily mean any shares are published or that we'll be able to see any of them. Actual enumeration of the shares is done via a different mechanism outside the scope of this program.
DC	This machine appears to be a Windows NT domain controller, either primary or secondary.
U=<i>user</i>	This machine appears to have a logged-in user with the name indicated. This is often only a guess, and it's common for our algorithms to miss a valid user (especially if the <i>user</i> name is the same as the <i>machine</i> name).
IIS	This machine appears to have Microsoft's Internet Information Server (IIS) installed, though we believe that there are related tools that can cause this to appear as well. It doesn't necessarily mean that IIS is actually running.
EXCHANGE	This machine appears to be running Microsoft Exchange.
NOTES	This machine appears to be running Lotus Notes
?	This means that the remote is advertising a NETBIOS resource record that we don't understand, and it can prompt us to run the scan again with the -f option and research it: we hope to use this feedback to make the program smarter in the future.

nbtscan is a tool often used by network administrators to identify devices and gather information about them on Windows networks.

NetBScanner Enumeration



Computers listed in the network neighbourhood comes from the browser-list maintained by the computer that is Master Browser. A computer can become Master Browser through an election where the computer with the highest priority is elected. Note that the MAC address is also shown.

Net View Enumeration

```
C:\Windows\system32>net view /?
The syntax of this command is:
```

```
NET VIEW
[\\computername [/CACHE] : [/ALL] : /DOMAIN[:domainname]]
```

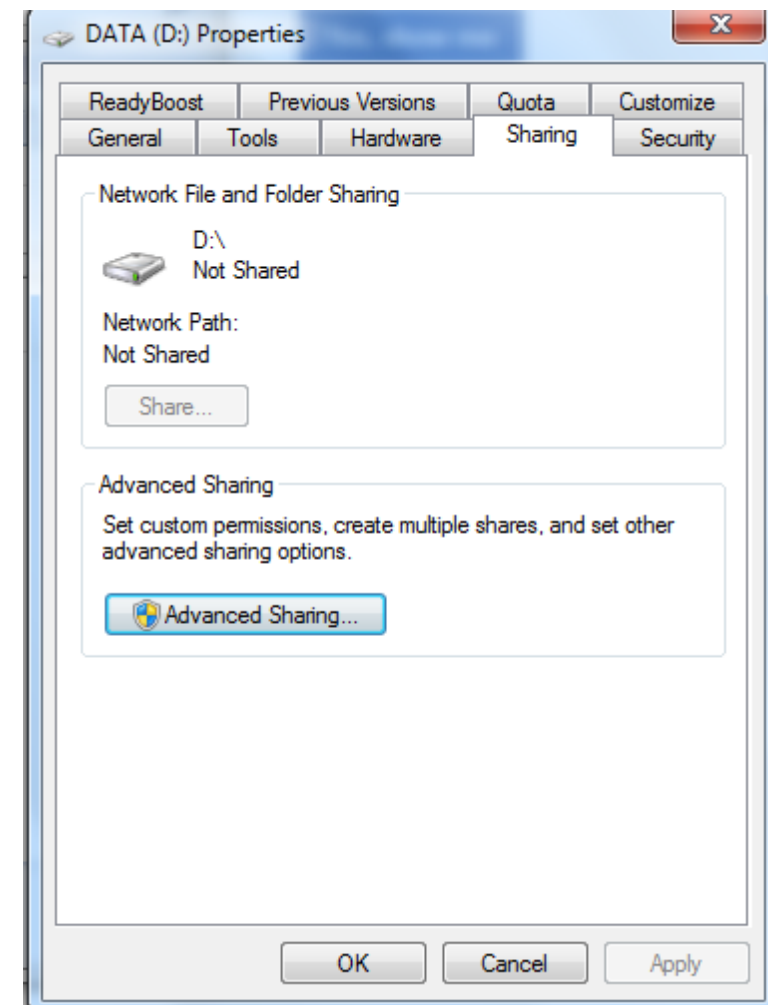
```
C:\Windows\system32>net view /all \\10.230.189.250
Shared resources at \\10.230.189.250

Samba 3.0.28a

Share name  Type  Used as  Comment
-----
IPC$        IPC    IPC Service (Samba 3.0.28a)
The command completed successfully.
```

```
C:\Windows\system32>net view /all \\10.230.189.134
Shared resources at \\10.230.189.134

Share name  Type  Used as  Comment
-----
ADMIN$      Disk  Remote Admin
C$          Disk  Default share
D$          Disk  Default share
E$          Disk  Default share
IPC$        IPC    Remote IPC
Users       Disk
The command completed successfully.
```



Net View is used in Windows to discover and list all shared network folders and printers.

Dumpsec Enumeration

Report -> Dump Permissions for Shares

Somarsoft DumpSec (formerly DumpAcl) - \\NB-X1YG2-S028 (local)

Share and path	Account	Own	Permission
ADMIN\$=C:\WINDOWS (special admin share)			admin-only (no dacl)
C\$=C:\ (special admin share)			admin-only (no dacl)
D\$=D:\ (special admin share)			admin-only (no dacl)
H\$=H:\ (special admin share)			admin-only (no dacl)
IPC\$= (special admin share)			admin-only (no dacl)

Report -> Dump Permissions for File System

Path (exception dacl) (exception dacl) files)	Account	Own	Dir	File
C:\Program Files				
C:\Program Files\TrustedInstaller			all	
C:\Program Files\SYSTEM			all	all
C:\Program Files\NB-X1YG2-S028\Administrators		o	all	all
C:\Program Files\NB-X1YG2-S028\Users			R X	R X
C:\Program Files\CREATOR OWNER				all
C:\Program Files\ALL APPLICATION PACKAGES			R X	R X
C:\Program Files\ALL RESTRICTED APPLICATION PACKAGES			R X	R X

DumpSec is a classic, lightweight Windows security auditing tool used by system administrators and penetration testers.

- Nessus: identify vulnerabilities, policy-violating configurations

<http://www.tenable.com/products/nessus-vulnerability-scanner>

Nessus

Scans Settings

FOLDERS

My Scans

All Scans

Trash

RESOURCES

Policies

Plugin Rules

Customized Reports

Scanners

Live Results Scan

Configure Audit Trail Launch Export

Hosts 1 Vulnerabilities 45 History 1

Filter Search Vulnerabilities 45 Vulnerabilities

Sev	Name	Family	Count
CRITICAL	Mozilla Foundation Unsupported Application ...	MacOS X Local Security Checks	1
HIGH	Mozilla Firefox < 59 Multiple Vulnerabilities (m...	MacOS X Local Security Checks	1
HIGH	Mozilla Firefox < 59.0.1 Multiple Code Executi...	MacOS X Local Security Checks	1
HIGH	Mozilla Firefox < 59.0.2 Denial of Service Vuln...	MacOS X Local Security Checks	1
HIGH	Mozilla Firefox < 60 Multiple Critical Vulnerabili...	MacOS X Local Security Checks	1
HIGH	Mozilla Firefox < 61 Multiple Critical Vulnerabili...	MacOS X Local Security Checks	1
HIGH	Mozilla Firefox < 62 Multiple Critical Vulnerabili...	MacOS X Local Security Checks	1
MEDIUM	SSL Certificate Cannot Be Trusted	General	1
INFO	Netstat Portscanner (SSH)	Port scanners	16
INFO	Service Detection	Service detection	4
INFO	HTTP Server Type and Version	Web Servers	2
INFO	Additional DNS Hostnames	General	1

Notice: This scan has been updated with Live Results. Launch a new scan to confirm these findings or remove them.

Scan Details

Name: Live Results Scan

Status: Completed

Policy: Advanced Scan

Scanner: Local Scanner

Modified: Today at 6:03 PM (Live Results)

Vulnerabilities

Critical

High

Medium

Low

Info

Additional Enumeration Tools

- NetScanTools Pro: internet information gathering
<http://www.netscantools.com/nstpromain.html>
- DumpSec: reporting security, directory, registry, and event info
<http://www.systemtools.com/somarsoft/?somarsoft.com>
- Hyena: <http://www.systemtools.com/hyena/>
- Netcat: <https://nmap.org/ncat/> , joncraton.org/files/nc111nt.zip

Summary

- **Ping Sweeps -> Port Scans**

- Protocol Rules – RFC 1122 (ICMP), RFC 793 (TCP), RFC 768 (UDP)
- Scanning Techniques and Tools; Sub-domains list
- Advanced Scanning Techniques and Tools

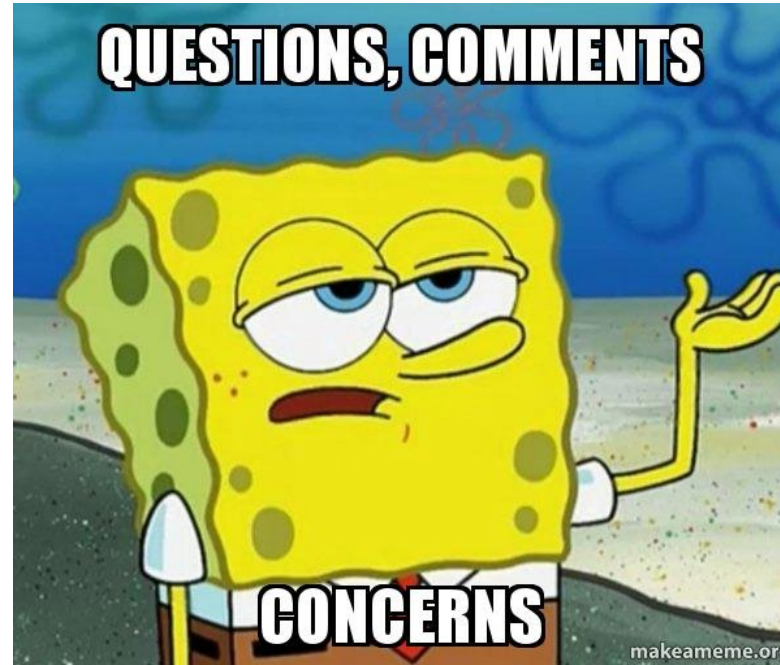
- **Route Tracing**

- Determine route between source and destination
- May help reveal new pen-test vectors / supports lateral movement

- **Enumeration**

- Determine OS and service vulnerabilities, resource shares, user accounts etc.
- Identified vulnerabilities give indication on gaining access
- Many available tools – must use a combination to obtain comprehensive enumeration

- **Next Lecture – Sniffing**



QUESTIONS OR COMMENTS?